

Análisis de riesgos y diseño de un plan de ciberseguridad aplicado a un entorno eHealth con datos sensibles

Trabajo de Fin de Grado

Alumno: _____

Tutor: _____

Curso académico 2025–2026

Índice

1. Introducción	4
1.1. Justificación del tema	4
1.2. Objetivo general	5
1.3. Objetivos específicos	5
1.4. Alcance del trabajo	6
1.5. Planificación y fases del trabajo	6
2. Estado del arte y marco teórico	7
2.1. Ciberseguridad en sistemas de información con datos sensibles	7
2.2. Concepto de riesgo, amenaza, vulnerabilidad e impacto	10
2.3. Metodologías de análisis de riesgos	12
2.4. Normativa y estándares aplicables	13
3. Descripción del entorno de estudio	15
3.1. Caracterización de la organización	15
3.2. Sistemas, infraestructura y servicios	17

3.3. Datos tratados y criticidad	19
3.4. Supuestos y limitaciones del caso	20
4. Metodología de análisis de riesgos	21
4.1. Fases metodológicas	22
4.2. Escalas de probabilidad e impacto	22
4.3. Matriz de clasificación	23
4.4. Criterios de tratamiento del riesgo	24
5. Análisis de riesgos del caso de estudio	24
5.1. Inventario de activos de información	24
5.2. Amenazas y vulnerabilidades	25
5.3. Matriz de riesgos inherentes	26
6. Diseño del plan de ciberseguridad	30
6.1. Controles seleccionados y alineación normativa	30
6.2. Hoja de ruta de implantación	33
6.3. Indicadores de reducción del riesgo	33
6.4. Riesgo residual estimado	34
7. Pequeña validación práctica	36
7.1. Objetivo y finalidad de la validación	36
7.2. Proceso seguido	37
7.3. Implementación del simulador	38
7.4. Resultados obtenidos	41
7.5. Discusión de resultados	45
7.6. Utilidad de la validación	46
7.7. Limitaciones y cierre de la validación	46

8. Conclusiones y líneas futuras	47
A. Anexos	49
A.1. Anexo A. Fragmentos representativos del simulador	49
A.2. Anexo B. Contenido del archivo <code>riesgos.csv</code>	52
A.3. Anexo C. Flujo de ejecución del simulador	53
B. Referencias	54

1. Introducción

La transformación digital ha incrementado de forma notable la dependencia de las organizaciones respecto a sus sistemas de información, hasta el punto de que la continuidad de muchas de sus actividades depende directamente de la disponibilidad, integridad y confidencialidad de los datos que gestionan. Este fenómeno resulta especialmente relevante en aquellos entornos que tratan información sensible, donde una incidencia de seguridad no solo afecta al funcionamiento operativo de la entidad, sino que puede comprometer derechos fundamentales de las personas afectadas, generar perjuicios económicos significativos y derivar en consecuencias legales y reputacionales de gran impacto.

Dentro de este contexto, el ámbito eHealth constituye un escenario particularmente adecuado para el estudio de la ciberseguridad. La gestión de historiales clínicos, datos identificativos, informes diagnósticos, resultados de pruebas médicas y credenciales de profesionales sanitarios configura un ecosistema informacional de alta criticidad. Además, la creciente interconexión entre aplicaciones, servicios en la nube, dispositivos de acceso remoto y sistemas de gestión clínica amplía la superficie de exposición frente a amenazas como el ransomware, el phishing, los accesos no autorizados, las fugas de información o los errores humanos.

Este Trabajo de Fin de Grado se centra en el análisis de riesgos y en el diseño de un plan de ciberseguridad aplicable a una organización sanitaria de tamaño pequeño o mediano, concretamente una clínica privada especializada que maneja datos personales y clínicos de carácter sensible. El estudio adopta un enfoque principalmente teórico-aplicado: por una parte, se apoya en marcos conceptuales, estándares y normativa vigente; por otra, traslada dichos principios a un caso de estudio verosímil que permite desarrollar un análisis estructurado y coherente.

El valor académico del trabajo reside en integrar tres dimensiones complementarias. En primer lugar, la dimensión metodológica, al aplicar un proceso formal de identificación de activos, amenazas, vulnerabilidades y riesgos. En segundo lugar, la dimensión estratégica, al traducir el análisis en un plan de ciberseguridad compuesto por medidas técnicas, organizativas y normativas. En tercer lugar, la dimensión aplicada, al incorporar una pequeña implementación práctica en forma de simulador automático de riesgos, concebido como herramienta de apoyo para estimar niveles de exposición en función de ciertas características del sistema analizado.

De este modo, el trabajo pretende ofrecer una visión completa, razonada y realista de cómo una organización con datos sensibles puede abordar su seguridad desde una perspectiva preventiva y planificada, evitando aproximaciones improvisadas y favoreciendo una toma de decisiones basada en la evaluación del riesgo.

1.1. Justificación del tema

La elección de esta temática responde a la necesidad creciente de que las organizaciones adopten enfoques sistemáticos de ciberseguridad. En los últimos años, el número y la sofisticación de

los incidentes de seguridad han aumentado de manera constante, afectando tanto a grandes corporaciones como a entidades de menor tamaño que, en muchos casos, carecen de recursos especializados suficientes. Esta realidad hace especialmente interesante el estudio de entornos donde la protección de la información no puede entenderse como un elemento accesorio, sino como una condición esencial para la prestación del servicio.

En el caso de una clínica privada o centro sanitario de dimensión reducida o media, la ciberseguridad presenta un interés específico por varias razones. En primer lugar, los datos tratados tienen un valor especialmente alto, tanto desde la perspectiva operativa como desde la perspectiva de la privacidad. En segundo lugar, los fallos de seguridad pueden afectar directamente a la calidad asistencial y a la disponibilidad de servicios críticos. En tercer lugar, este tipo de organizaciones suele combinar necesidades elevadas de protección con limitaciones presupuestarias y organizativas, lo que obliga a priorizar medidas y a diseñar planes realistas y graduales.

Asimismo, el tema resulta adecuado para un Trabajo de Fin de Grado porque permite combinar fundamentos teóricos, análisis estructurado y aplicación práctica moderada. El desarrollo de una propuesta de plan de ciberseguridad basada en riesgos, complementada con un simulador sencillo de apoyo, proporciona un equilibrio apropiado entre profundidad conceptual, utilidad práctica y viabilidad dentro del alcance del proyecto.

1.2. Objetivo general

Diseñar un análisis de riesgos y un plan de ciberseguridad aplicados a una clínica privada del ámbito eHealth que trate datos sensibles, con el fin de identificar los principales riesgos que afectan a su sistema de información, priorizarlos de acuerdo con su probabilidad e impacto, y proponer medidas de mitigación alineadas con estándares y requisitos normativos vigentes.

1.3. Objetivos específicos

- Definir un caso de estudio realista, correspondiente a una clínica privada de tamaño pequeño o mediano, y describir su sistema de información, procesos principales y datos tratados.
- Identificar los activos críticos del entorno analizado, incluyendo información, sistemas, infraestructura tecnológica, personal y servicios asociados.
- Analizar las amenazas y vulnerabilidades más relevantes para el contexto de estudio, con especial atención a aquellas que afecten a la confidencialidad, integridad y disponibilidad de la información.
- Establecer criterios de evaluación basados en probabilidad e impacto para valorar y priorizar los riesgos detectados.
- Diseñar un plan de ciberseguridad compuesto por medidas técnicas, organizativas y de

cumplimiento normativo que permitan reducir el nivel de riesgo de forma razonable y viable.

- Desarrollar una pequeña implementación práctica consistente en un simulador automático de riesgos capaz de estimar niveles de exposición a partir de entradas asociadas al sistema analizado.
- Valorar las limitaciones del enfoque adoptado y proponer posibles líneas de mejora o ampliación futura.

1.4. Alcance del trabajo

El trabajo se limitará al diseño y análisis de un caso de estudio ficticio pero verosímil, inspirado en una clínica privada especializada que opera con datos personales y clínicos sensibles. No se realizará una auditoría sobre una organización real ni se llevará a cabo la implantación completa de controles de seguridad en un entorno productivo. En su lugar, se construirá un escenario suficientemente detallado como para aplicar una metodología formal de análisis de riesgos y plantear un plan de seguridad coherente con las necesidades de la organización descrita.

Desde el punto de vista temático, el estudio abarcará la identificación de activos, amenazas, vulnerabilidades y riesgos, así como la definición de medidas de tratamiento desde tres perspectivas: técnica, organizativa y normativa. La pequeña parte práctica se acotará al diseño de un simulador automático de riesgos con finalidad académica y demostrativa. Dicho simulador no sustituirá un análisis profesional completo, sino que servirá como apoyo conceptual para ilustrar cómo determinados factores del sistema pueden influir en la valoración del riesgo.

Finalmente, el trabajo no desarrolla en profundidad aspectos como la respuesta forense ante incidentes, la implantación real de un sistema de gestión de seguridad de la información o la certificación formal en estándares internacionales. Estos elementos quedan fuera del alcance principal y se consideran únicamente como posibles líneas de ampliación futura.

1.5. Planificación y fases del trabajo

El desarrollo del TFG se organiza en cinco fases. La primera fase consiste en la revisión bibliográfica y normativa, centrada en gestión de riesgos, protección de datos, estándares de seguridad y contexto sanitario. La segunda fase define el caso de estudio SaludNova, incluyendo procesos, activos, usuarios, infraestructura y datos tratados. La tercera fase aplica la metodología de análisis de riesgos, identificando amenazas, vulnerabilidades, probabilidad, impacto y nivel de riesgo inherente. La cuarta fase diseña el plan de ciberseguridad y estima el riesgo residual tras la aplicación de controles. La quinta fase valida el modelo mediante un simulador sencillo que automatiza el cálculo y la visualización de resultados.

Esta planificación permite mantener el alcance dentro de una memoria de 40–50 páginas y evita

convertir el trabajo en un proyecto de desarrollo software, auditoría técnica o implantación completa de un SGSI. El esfuerzo principal se concentra en la trazabilidad entre activos, riesgos y controles, que constituye el núcleo académico del trabajo.

2. Estado del arte y marco teórico

Este capítulo reunirá los conceptos, modelos y referencias necesarios para fundamentar el trabajo. Su objetivo será situar el análisis dentro del contexto de la gestión de riesgos de seguridad de la información y de la protección de datos sensibles. Para ello, el desarrollo teórico del TFG se apoyará en normativa oficial, estándares internacionales y guías técnicas de referencia, entre ellas el RGPD, la LOPDGDD, las normas ISO/IEC 27001 e ISO/IEC 27002, guías metodológicas como NIST SP 800-30 y documentación sectorial aplicable al ámbito sanitario [1–10].

2.1. Ciberseguridad en sistemas de información con datos sensibles

La ciberseguridad constituye un elemento esencial en cualquier sistema de información moderno, pero adquiere una relevancia especialmente elevada cuando dicho sistema procesa, almacena o transmite datos sensibles. En este tipo de entornos, la seguridad no puede entenderse únicamente como una cuestión técnica vinculada a la instalación de herramientas de protección, sino como un conjunto de medidas organizativas, procedimentales y tecnológicas orientadas a preservar el valor de la información y a garantizar que los procesos de la organización puedan desarrollarse de forma fiable. Esta visión resulta coherente con el enfoque de los sistemas de gestión de seguridad de la información, en los que la protección de los activos se aborda mediante políticas, responsabilidades, controles, evaluación de riesgos y mejora continua [3, 4].

Desde una perspectiva clásica, la seguridad de la información se articula en torno a tres propiedades fundamentales: confidencialidad, integridad y disponibilidad. La confidencialidad implica que la información solo sea accesible por personas, procesos o sistemas autorizados. En una organización que maneja datos sensibles, esta propiedad es crítica porque una exposición no autorizada puede afectar directamente a la privacidad de las personas, revelar información íntima o permitir usos indebidos de los datos. La integridad, por su parte, garantiza que la información se mantiene completa, exacta y libre de modificaciones no autorizadas o accidentales. Su pérdida puede conducir a decisiones erróneas, alteración de registros, inconsistencias administrativas o incluso daños sobre las personas afectadas si la información se utiliza para prestar un servicio esencial. Finalmente, la disponibilidad asegura que los datos y sistemas estén accesibles cuando son necesarios. En organizaciones cuya actividad depende de sistemas digitales, una interrupción prolongada puede paralizar procesos críticos, impedir la prestación de servicios y provocar pérdidas económicas o reputacionales.

Estas tres propiedades no deben analizarse de forma aislada, ya que en la práctica se encuentran estrechamente relacionadas. Un incidente de ransomware, por ejemplo, afecta principalmente a la

disponibilidad al cifrar sistemas o archivos, pero también puede comprometer la confidencialidad si el atacante extrae información antes del cifrado, y la integridad si los datos son modificados o destruidos. Del mismo modo, un acceso no autorizado a una aplicación corporativa puede comenzar como una brecha de confidencialidad, pero derivar en alteraciones de registros, eliminación de evidencias o interrupción de procesos. Por ello, la ciberseguridad en entornos con datos sensibles debe abordarse desde una visión integral que contemple escenarios de amenaza combinados y que no limite el análisis a un único tipo de impacto.

La importancia de proteger adecuadamente los datos sensibles se justifica tanto por razones técnicas como legales y éticas. Desde el punto de vista técnico, estos datos suelen tener un alto valor para la organización y para terceros malintencionados. Pueden utilizarse para fraude, extorsión, suplantación de identidad, ingeniería social o venta en mercados ilícitos. Desde el punto de vista legal, el Reglamento General de Protección de Datos establece obligaciones específicas para el tratamiento de datos personales y exige que los responsables apliquen medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo [1]. Desde una perspectiva ética, la organización tiene una responsabilidad directa frente a las personas cuyos datos gestiona, especialmente cuando existe una relación de confianza o dependencia entre el usuario y la entidad.

En este contexto, la pérdida de datos representa uno de los riesgos más relevantes. La pérdida puede producirse por causas intencionadas, como un ataque informático, o por causas accidentales, como errores humanos, fallos de hardware, eliminación involuntaria de archivos o deficiencias en las copias de seguridad. Aunque en ocasiones se asocia la pérdida de datos únicamente con la desaparición definitiva de información, también debe considerarse pérdida la imposibilidad temporal de acceder a datos necesarios para operar. En una organización que depende de sistemas digitales para gestionar su actividad, no disponer de la información en el momento adecuado puede generar impactos similares a su eliminación, especialmente si no existen procedimientos alternativos ni mecanismos de recuperación verificados.

Los accesos no autorizados constituyen otro riesgo central en sistemas con datos sensibles. Este tipo de incidente puede producirse mediante credenciales robadas, contraseñas débiles, ausencia de autenticación multifactor, permisos mal asignados, cuentas obsoletas o abuso de privilegios por parte de usuarios internos. Su gravedad reside en que el atacante puede operar aparentemente como un usuario legítimo, lo que dificulta la detección y puede prolongar el tiempo de exposición. Además, no todos los accesos indebidos proceden del exterior de la organización. También pueden existir accesos internos no justificados, consultas excesivas de información, uso de cuentas compartidas o falta de segregación de funciones. Por este motivo, la gestión de identidades, el principio de mínimo privilegio, la revisión periódica de permisos y la trazabilidad de accesos son elementos fundamentales para reducir el riesgo.

Los ataques informáticos añaden una dimensión adicional al problema, ya que explotan vulnerabilidades técnicas, organizativas o humanas para comprometer sistemas y datos. Entre los escenarios más habituales se encuentran el phishing, la distribución de malware, el ransomware, la explotación de servicios expuestos, el compromiso de proveedores, la manipulación de confi-

guraciones inseguras o el uso de credenciales filtradas. En organizaciones pequeñas o medianas, estos ataques pueden tener un impacto especialmente elevado porque suelen existir limitaciones presupuestarias, menor especialización técnica y dependencia de proveedores externos. Esta situación no implica necesariamente ausencia de seguridad, pero sí obliga a priorizar controles proporcionados, eficaces y sostenibles.

El sector sanitario constituye un caso especialmente representativo de esta problemática. Los sistemas de información sanitarios procesan datos clínicos, diagnósticos, tratamientos, antecedentes, resultados de pruebas, datos identificativos y documentación administrativa. Esta información posee una sensibilidad superior a la de otros tipos de datos personales, ya que afecta directamente a la intimidad de los pacientes y puede revelar aspectos especialmente delicados de su vida. Además, los datos clínicos no solo deben protegerse por razones de privacidad, sino también porque su exactitud y disponibilidad pueden influir en la calidad de la atención. Un historial alterado, un resultado no disponible o un informe enviado al destinatario equivocado pueden generar consecuencias que van más allá del ámbito administrativo.

En entornos eHealth, la digitalización ha aportado ventajas evidentes, como la mejora del acceso a la información, la coordinación entre profesionales, la reducción de tiempos de gestión y la posibilidad de prestar servicios remotos. Sin embargo, también ha ampliado la superficie de exposición. Las aplicaciones de gestión clínica, los servicios en la nube, el correo electrónico, los portales de pacientes, los sistemas de cita previa, las copias de seguridad y los accesos remotos introducen dependencias tecnológicas que deben ser evaluadas. La seguridad sanitaria, por tanto, no se limita a proteger una base de datos, sino que abarca el conjunto de procesos, personas, sistemas y proveedores que intervienen en el ciclo de vida de la información clínica.

La norma ISO 27799 resulta especialmente relevante en este ámbito porque adapta los controles de seguridad de la información al contexto sanitario y pone el foco en la protección de la información de salud [6]. Su utilidad para un trabajo como el presente reside en que permite conectar principios generales de seguridad con necesidades propias del sector, como la trazabilidad de accesos a información clínica, la confidencialidad reforzada, la continuidad de los servicios asistenciales y la gestión segura de comunicaciones con terceros. Esta perspectiva complementa el enfoque de ISO/IEC 27001, que proporciona un marco de gestión para establecer, implementar, mantener y mejorar un sistema de gestión de seguridad de la información [3].

La relación entre ciberseguridad y protección de datos resulta especialmente clara en el ámbito sanitario. El RGPD no prescribe una lista cerrada de herramientas concretas, sino que exige aplicar medidas adecuadas al riesgo, teniendo en cuenta el estado de la técnica, los costes de aplicación, la naturaleza de los datos, el contexto del tratamiento y la probabilidad e impacto de los riesgos para los derechos y libertades de las personas [1]. Esto significa que la seguridad debe justificarse mediante un razonamiento basado en riesgos. No basta con afirmar que una organización dispone de antivirus o copias de seguridad; es necesario demostrar que las medidas seleccionadas responden a amenazas reales, protegen activos críticos y reducen la probabilidad o el impacto de incidentes relevantes.

En una clínica privada como la planteada en este TFG, la ciberseguridad debe entenderse como una condición necesaria para garantizar la confianza del paciente y la continuidad de la actividad. La organización no necesita necesariamente implantar controles propios de una gran infraestructura hospitalaria, pero sí debe asegurar que sus medidas son coherentes con los datos que trata y con los riesgos a los que está expuesta. La autenticación robusta, el control de accesos, la segregación de redes, el cifrado de dispositivos, la formación del personal, las copias de seguridad verificadas, la gestión de proveedores y la existencia de procedimientos de respuesta a incidentes son ejemplos de medidas que responden a necesidades concretas en este tipo de entorno.

Además, la ciberseguridad no debe considerarse un estado final, sino un proceso continuo. Las amenazas evolucionan, los sistemas cambian, aparecen nuevos proveedores, se incorporan usuarios, se modifican procesos y surgen nuevas obligaciones o recomendaciones. Por tanto, una organización que maneja datos sensibles debe revisar periódicamente sus riesgos, actualizar sus controles y mantener evidencias de las decisiones adoptadas. Esta idea de mejora continua es coherente con los marcos de gestión de seguridad y con la lógica de un plan de ciberseguridad basado en riesgos [3, 10].

En síntesis, la ciberseguridad en sistemas de información con datos sensibles tiene una función preventiva, protectora y habilitadora. Preventiva, porque reduce la probabilidad de incidentes; protectora, porque limita el impacto cuando estos se producen; y habilitadora, porque permite que la organización utilice tecnologías digitales manteniendo un nivel razonable de confianza, cumplimiento y continuidad. En el caso sanitario, esta función adquiere una dimensión adicional debido a la naturaleza de los datos clínicos y a la relación directa entre información, privacidad y calidad asistencial. Por ello, el análisis de riesgos y el diseño de un plan de ciberseguridad resultan instrumentos adecuados para estructurar la protección de una clínica como SaludNova y para justificar, de forma ordenada, las medidas que se propondrán en los capítulos posteriores.

2.2. Concepto de riesgo, amenaza, vulnerabilidad e impacto

El análisis de riesgos requiere utilizar una terminología precisa, ya que una parte importante de la calidad metodológica del trabajo depende de distinguir correctamente los elementos que intervienen en la materialización de un incidente de seguridad. En el contexto de este TFG, el riesgo no se entiende como una amenaza aislada ni como una vulnerabilidad concreta, sino como la posibilidad de que una amenaza aproveche una debilidad existente y genere un impacto sobre uno o varios activos de la organización. Esta interpretación es coherente con el enfoque de NIST SP 800-30, que relaciona amenazas, vulnerabilidades, probabilidad, impacto y nivel de riesgo como elementos de un mismo proceso de evaluación [10].

Un activo es cualquier elemento que tiene valor para la organización y que, por tanto, debe ser protegido. En una clínica privada como SaludNova, los activos no se limitan a equipos informáticos o aplicaciones, sino que incluyen datos clínicos, credenciales, documentos administrativos, servicios en la nube, red local, personal, proveedores y procesos de negocio. Esta visión amplia es importante porque algunos riesgos relevantes no proceden únicamente de fallos técnicos, sino

también de errores organizativos, permisos mal definidos, falta de formación o dependencias con terceros. Por ello, el inventario de activos constituye el punto de partida del análisis: no puede valorarse adecuadamente un riesgo si previamente no se ha identificado qué elemento se quiere proteger y qué valor tiene para la continuidad, privacidad y funcionamiento de la clínica.

Una amenaza es un evento o agente capaz de causar un daño sobre un activo. Puede tener origen externo, como un ataque de ransomware, una campaña de phishing o el compromiso de un proveedor, pero también puede tener origen interno, como un error humano, un acceso indebido por parte de un empleado o una configuración incorrecta. En el ámbito sanitario, las amenazas adquieren especial gravedad porque los datos tratados combinan valor operativo, sensibilidad personal y relevancia asistencial. Un atacante puede buscar beneficio económico mediante extorsión o venta de información, mientras que un error interno puede provocar una fuga de datos o afectar a la disponibilidad de información clínica necesaria para la atención.

La vulnerabilidad es la debilidad que permite o facilita que una amenaza se materialice. No equivale al incidente en sí, sino a la condición que hace posible o más probable que ocurra. Ejemplos de vulnerabilidades en SaludNova son la ausencia de autenticación multifactor, la falta de segmentación entre redes, las copias de seguridad no verificadas, los permisos excesivos, la inexistencia de procedimientos de envío seguro o la dependencia de accesos remotos del proveedor TIC sin trazabilidad suficiente. Esta distinción es esencial para que el plan de ciberseguridad sea coherente: las medidas no deben dirigirse solo contra amenazas genéricas, sino contra vulnerabilidades concretas que incrementan la exposición de los activos.

El impacto representa la consecuencia que tendría la materialización de un riesgo. En este trabajo se analiza desde varias dimensiones: confidencialidad, integridad, disponibilidad, cumplimiento normativo, reputación, continuidad operativa y posible afectación a los pacientes. En un entorno eHealth, el impacto no puede limitarse al coste económico de recuperar un sistema. La exposición de informes clínicos, la modificación de un historial, la imposibilidad de acceder a resultados de pruebas o la pérdida de trazabilidad sobre quién ha consultado determinados datos pueden generar consecuencias legales, asistenciales y éticas. Por este motivo, la escala de impacto utilizada en la metodología distingue entre incidencias menores, afectaciones operativas moderadas y escenarios graves que comprometen datos sanitarios o paralizan servicios críticos.

La probabilidad expresa la estimación razonada de que una amenaza se materialice sobre un activo concreto teniendo en cuenta las vulnerabilidades existentes. En este TFG no se dispone de estadísticas internas de incidentes de la clínica, ya que el caso es ficticio; por ello, la probabilidad se valora de forma semicuantitativa mediante una escala de 1 a 5. Esta decisión introduce una limitación metodológica, pero resulta adecuada para el alcance académico del trabajo si se aplican criterios explícitos y consistentes. La probabilidad no se asigna de forma arbitraria, sino considerando factores como exposición a Internet, frecuencia de uso del sistema, atractivo del activo, existencia de controles, facilidad de explotación y dependencia de usuarios o proveedores.

El riesgo inherente es el nivel de riesgo estimado antes de aplicar controles adicionales a los ya existentes en el escenario. En cambio, el riesgo residual es el nivel que permanece después de

definir medidas de tratamiento. Esta diferencia es fundamental para el trabajo, porque permite justificar la utilidad del plan de ciberseguridad: no basta con enumerar controles, sino que debe mostrarse cómo dichos controles reducen la probabilidad o el impacto de los riesgos priorizados. La trazabilidad activo–amenaza–vulnerabilidad–riesgo–control–riesgo residual constituye, por tanto, el eje metodológico del TFG y el principal criterio para evaluar si el análisis es defendible.

Finalmente, una salvaguarda o control es una medida destinada a reducir la probabilidad de materialización de una amenaza, disminuir su impacto o mejorar la capacidad de detección y respuesta. En el caso de SaludNova, los controles se clasifican en técnicos, organizativos y normativos. Esta clasificación evita una visión exclusivamente tecnológica de la ciberseguridad y permite conectar medidas como MFA, copias verificadas o segmentación de red con otras como formación, revisión de roles, contratos con proveedores y procedimientos de notificación de incidentes. El resultado buscado no es eliminar por completo el riesgo, algo irrealista en cualquier organización, sino reducirlo hasta un nivel aceptable y documentado.

2.3. Metodologías de análisis de riesgos

Las metodologías de análisis de riesgos proporcionan un marco ordenado para identificar activos, amenazas, vulnerabilidades e impactos, evitando que la selección de controles se base únicamente en intuiciones o listas genéricas de buenas prácticas. En ciberseguridad, este enfoque resulta especialmente relevante porque los recursos son limitados y no todos los riesgos tienen la misma prioridad. Una metodología adecuada permite justificar por qué se tratan primero determinados escenarios, qué criterios se han utilizado para valorar la gravedad y cómo se relacionan las medidas propuestas con los riesgos identificados.

NIST SP 800-30 constituye la referencia metodológica principal de este TFG. Su utilidad reside en que plantea la evaluación de riesgos como un proceso estructurado, centrado en identificar fuentes de amenaza, eventos, vulnerabilidades, condiciones predisponentes, probabilidad de ocurrencia, impacto y determinación del riesgo [10]. Esta lógica encaja con el objetivo del trabajo porque permite construir una cadena clara entre el entorno de SaludNova y las decisiones de seguridad posteriores. Además, su formulación es suficientemente flexible para adaptarse a un caso académico sin exigir la implantación de una herramienta profesional o la disponibilidad de métricas históricas reales.

El uso de una matriz semicuantitativa Probabilidad $\times$ Impacto responde a la necesidad de equilibrar rigor y viabilidad. Un análisis puramente cualitativo podría resultar demasiado subjetivo, mientras que un análisis cuantitativo completo exigiría datos económicos, históricos y estadísticos que no están disponibles en una clínica ficticia y que excederían el alcance del TFG. La escala de 1 a 5 permite establecer una priorización reproducible, siempre que los criterios de asignación estén definidos y se apliquen de forma consistente. Por tanto, la matriz no pretende ofrecer una medición exacta del riesgo, sino una estimación razonada que facilite la toma de decisiones.

MAGERIT es una alternativa especialmente relevante en el contexto español, ya que proporciona una metodología detallada para el análisis y gestión de riesgos de los sistemas de información [8]. Su principal fortaleza es la profundidad con la que estructura activos, amenazas, salvaguardas, valoración e impacto. Sin embargo, precisamente esa profundidad puede convertirse en una desventaja para este trabajo: una aplicación completa de MAGERIT requeriría un nivel de detalle documental, catálogos y descomposición de activos que podría desplazar el foco del TFG desde el análisis aplicado hacia la cumplimentación metodológica. Por este motivo, MAGERIT se considera una referencia válida, pero no se adopta como metodología principal.

ISO/IEC 27005 también ofrece orientación específica para la gestión de riesgos de seguridad de la información y resulta coherente con la familia ISO/IEC 27001 [5]. Su papel en este TFG es complementario: ayuda a situar la gestión del riesgo dentro de un enfoque de mejora continua y alineación con controles de seguridad, pero no se utiliza como proceso principal para evitar duplicidad metodológica. En términos prácticos, NIST SP 800-30 se emplea para estructurar el análisis, mientras que ISO/IEC 27001, ISO/IEC 27002 e ISO 27799 se utilizan para orientar el diseño de controles y su adecuación al ámbito sanitario.

El NIST Cybersecurity Framework 2.0 también resulta útil como referencia conceptual, especialmente por su organización en funciones de gobierno, identificación, protección, detección, respuesta y recuperación [9]. No obstante, se mantiene como marco de apoyo y no como metodología central. Su inclusión completa podría ampliar innecesariamente el alcance del trabajo y generar solapamientos con ISO 27001 e ISO 27002. En consecuencia, el TFG adopta una estrategia deliberadamente acotada: una metodología principal para valorar riesgos y un conjunto reducido de estándares para justificar controles.

La principal limitación del enfoque adoptado es la subjetividad inherente a la valoración semicuantitativa. Las puntuaciones de probabilidad e impacto dependen de supuestos razonados sobre SaludNova y no de datos reales de incidentes. Para mitigar esta debilidad, el trabajo define escalas explícitas, mantiene un número limitado de riesgos, documenta vulnerabilidades asociadas y reevalúa el riesgo residual de forma trazable. Esta decisión mejora la defendibilidad del análisis ante un tribunal, ya que permite explicar cada puntuación y discutirla sin depender de una supuesta exactitud numérica que el caso de estudio no puede proporcionar.

2.4. Normativa y estándares aplicables

El marco normativo y de estándares cumple una doble función en este TFG. Por un lado, proporciona fundamentos para justificar por qué determinados activos y riesgos son especialmente relevantes en una clínica privada. Por otro, orienta la selección de controles de seguridad de forma que el plan no sea una colección arbitraria de medidas, sino una propuesta alineada con buenas prácticas reconocidas y obligaciones aplicables al tratamiento de datos sensibles.

El Reglamento General de Protección de Datos constituye la referencia legal principal en materia de protección de datos personales dentro de la Unión Europea [1]. Su relevancia para el caso

SaludNova es directa, ya que la clínica trata datos relativos a la salud, considerados categorías especiales de datos. Desde la perspectiva del TFG, el RGPD aporta tres ideas clave: la necesidad de aplicar medidas técnicas y organizativas apropiadas al riesgo, la importancia de garantizar confidencialidad, integridad, disponibilidad y resiliencia de los sistemas, y la obligación de gestionar adecuadamente las brechas de seguridad que puedan afectar a datos personales. Estas exigencias refuerzan la necesidad de un análisis de riesgos previo y justifican que el plan de ciberseguridad incluya controles de acceso, trazabilidad, copias de seguridad, procedimientos de incidentes y gestión de proveedores.

La LOPDGDD complementa el RGPD en el ordenamiento español y resulta pertinente por el contexto nacional del trabajo [7]. Aunque el TFG no realiza una auditoría jurídica exhaustiva ni una evaluación de impacto de protección de datos formal, sí considera que el tratamiento de información clínica exige medidas reforzadas, responsabilidades claras y documentación suficiente. Esta delimitación es importante para evitar una confusión frecuente: el trabajo no pretende demostrar cumplimiento legal completo, sino integrar requisitos de protección de datos en un plan técnico y organizativo de ciberseguridad.

ISO/IEC 27001 se utiliza como referencia de gestión para estructurar la seguridad de la información desde una perspectiva organizativa [3]. No se plantea la implantación ni certificación de un SGSI completo, porque ello excedería el alcance del TFG. Sin embargo, la norma resulta útil para justificar la necesidad de gobierno, evaluación de riesgos, tratamiento, mejora continua, responsabilidades y revisión periódica. En este sentido, ISO/IEC 27001 aporta el marco de gestión, mientras que el análisis de riesgos desarrollado en el trabajo proporciona la base para decidir qué controles son prioritarios en SaludNova.

ISO/IEC 27002 actúa como catálogo de referencia para seleccionar controles concretos [4]. Su utilidad reside en que permite vincular los riesgos identificados con medidas reconocibles, como gestión de identidades, control de accesos, concienciación, protección frente a malware, copias de seguridad, registro de eventos, seguridad de redes, gestión de proveedores y respuesta a incidentes. Esta relación es fundamental para la trazabilidad del trabajo: cada control propuesto debe responder a uno o varios riesgos, y no aparecer como una recomendación genérica sin conexión con el análisis previo.

ISO 27799 aporta la adaptación sectorial al ámbito sanitario, al orientar la aplicación de controles de seguridad de la información sobre información de salud [6]. En el caso de SaludNova, esta referencia refuerza la importancia de la confidencialidad de los datos clínicos, la trazabilidad de accesos a historias, la disponibilidad de información asistencial y la gestión segura de comunicaciones con terceros. Su inclusión evita que el plan se perciba como un plan genérico para cualquier pyme y lo conecta de forma explícita con el entorno eHealth.

Por último, las referencias de ENISA y NIST se utilizan como apoyo para contextualizar amenazas, buenas prácticas y gestión del riesgo en entornos digitalizados [2, 9, 10]. Su función no es ampliar el alcance metodológico, sino respaldar la selección de amenazas y la necesidad de un enfoque preventivo, documentado y revisable. En conjunto, el marco normativo y técnico

seleccionado resulta suficiente para una memoria de 45–50 páginas: cubre protección de datos, gestión de seguridad, catálogo de controles, especificidad sanitaria y metodología de riesgo sin derivar hacia una implantación completa de ISO 27001, ENS, pentesting o auditoría real.

3. Descripción del entorno de estudio

En este capítulo se define el caso de estudio sobre el que se aplicará el análisis de riesgos. La organización considerada es *Clínica SaludNova*, una clínica privada ficticia de tamaño pequeño-medio dedicada a consultas ambulatorias, seguimiento de pacientes crónicos y realización de pruebas diagnósticas básicas. El caso no representa una entidad real, pero se ha construido con características plausibles para que el análisis sea defendible desde un punto de vista técnico y ajustado al alcance de un TFG de 15 créditos.

La finalidad de esta definición no es describir todos los detalles operativos de una organización sanitaria, sino delimitar un entorno suficientemente concreto para identificar activos, amenazas, vulnerabilidades, riesgos y controles. Esta aproximación permite aplicar una metodología formal sin necesidad de realizar una auditoría real ni de acceder a datos sanitarios auténticos.

3.1. Caracterización de la organización

Clínica SaludNova atiende aproximadamente a 8.000 pacientes activos y realiza unas 450 consultas semanales. Dispone de una sede física con área de recepción, consultas médicas, sala de enfermería, sala de pruebas diagnósticas, despacho de dirección, archivo administrativo y cuarto técnico. Su horario de atención es de lunes a viernes, aunque determinados servicios digitales, como la solicitud de cita o la consulta de resultados, están disponibles fuera del horario presencial.

La plantilla se compone de perfiles sanitarios, administrativos y de soporte. El soporte informático está externalizado en un proveedor que realiza mantenimiento preventivo, resolución de incidencias y administración básica de sistemas. Esta situación es habitual en organizaciones pequeñas y medianas, pero introduce dependencias relevantes: la clínica necesita medidas de seguridad suficientes, aunque no dispone de un departamento interno especializado en ciberseguridad.

Perfil	Número	Funciones principales
Dirección y gerencia	2	Gestión estratégica, relación con proveedores, decisiones presupuestarias y supervisión del cumplimiento normativo.
Personal médico	8	Consulta de historiales, emisión de diagnósticos, prescripción, elaboración de informes y revisión de resultados.

Enfermería y técnicos	5	Registro de constantes, apoyo a pruebas diagnósticas, carga de documentos clínicos y atención asistencial.
Administración y recepción	6	Gestión de citas, admisión, facturación, comunicación con pacientes y tratamiento de documentación identificativa.
Responsable interno de protección de datos	1	Función asumida parcialmente por gerencia: coordinación de solicitudes de derechos, revisión de contratos y contacto con asesoría externa.
Proveedor TIC externo	1 contrato	Mantenimiento de equipos, copias de seguridad, correo, red local, actualizaciones y soporte remoto.

La caracterización organizativa permite identificar perfiles con responsabilidades diferenciadas sobre la información. Esta distinción resulta necesaria para valorar riesgos asociados a permisos excesivos, accesos internos no justificados, dependencia del proveedor TIC y ausencia de un equipo especializado de ciberseguridad.

Desde el punto de vista del análisis de riesgos, la distribución de perfiles evidencia que la seguridad de la información en SaludNova depende de una combinación de usuarios con necesidades muy distintas. El personal médico requiere acceso amplio y rápido a información clínica para poder realizar diagnósticos, consultar antecedentes y revisar resultados. El personal de enfermería y técnicos necesita registrar información asistencial y acceder a determinados datos de pacientes durante la atención. Administración y recepción, por su parte, trabajan principalmente con información identificativa, citas, documentación y facturación, pero también pueden actuar como punto de entrada de errores o incidentes al comunicarse de forma continua con pacientes, aseguradoras, laboratorios y proveedores.

Esta diversidad de funciones genera una tensión habitual en entornos sanitarios pequeños: el sistema debe facilitar el acceso ágil a la información para no entorpecer la actividad asistencial, pero al mismo tiempo debe limitar los permisos para evitar accesos excesivos o no justificados. En una clínica de este tamaño, la tendencia operativa puede ser simplificar la gestión de usuarios mediante perfiles demasiado amplios o mediante procedimientos informales. Sin embargo, desde el punto de vista de la confidencialidad y trazabilidad, esta práctica incrementa el riesgo de consultas indebidas, modificación accidental de registros o dificultad para atribuir responsabilidades ante un incidente.

La externalización del soporte TIC también condiciona el modelo de riesgo. Para una organización pequeña o mediana resulta razonable no disponer de un equipo interno especializado, pero esta decisión traslada parte de la administración técnica a un tercero. El proveedor puede tener acceso remoto, capacidad de modificar configuraciones, gestionar copias de seguridad o intervenir sobre cuentas y equipos. Por tanto, no debe considerarse únicamente como un recurso de apoyo, sino

como un actor relevante dentro del sistema de información. Esta dependencia justifica que en capítulos posteriores se valoren riesgos asociados al acceso remoto, a la gestión de proveedores y a la ausencia de controles formales sobre intervenciones técnicas.

3.2. Sistemas, infraestructura y servicios

El sistema de información combina servicios locales y servicios en la nube. La clínica utiliza una aplicación de gestión clínica en modalidad SaaS, accesible mediante navegador, en la que se registran citas, pacientes, informes, antecedentes, prescripciones y resultados. Además, dispone de correo electrónico corporativo, almacenamiento documental compartido, sistema de facturación, impresoras multifunción, red Wi-Fi para personal y red separada para pacientes.

Componente	Descripción	Relevancia para la seguridad
Aplicación de gestión clínica	Servicio SaaS para historial clínico, agenda, informes y resultados.	Activo central; una indisponibilidad o acceso indebido afectaría directamente a la actividad asistencial.
Puestos de trabajo	18 equipos Windows para consultas, recepción, administración y dirección.	Punto habitual de entrada de malware, phishing y accesos no autorizados.
Red local cableada	Conecta equipos, impresoras y dispositivos del cuarto técnico.	Requiere segmentación y control para evitar movimientos laterales.
Red Wi-Fi corporativa y de invitados	Acceso inalámbrico para personal y pacientes.	Debe separarse para impedir que dispositivos no confiables alcancen sistemas internos.
Correo electrónico corporativo	Comunicación con pacientes, laboratorios, aseguradoras y proveedores.	Vector principal de phishing, envío erróneo de información y fuga de datos.
Almacenamiento documental	Repositorio para informes, consentimientos, contratos y documentación administrativa.	Necesita control de permisos, cifrado y trazabilidad de accesos.
Copias de seguridad	Copias de datos críticos y configuración de sistemas.	Control esencial frente a ransomware, borrado accidental e indisponibilidad del proveedor.
Soporte remoto	Acceso del proveedor TIC para mantenimiento.	Requiere autenticación robusta, registro de sesiones y limitación temporal.

Los servicios críticos de negocio son la gestión de citas, el acceso a historial clínico, la emisión de informes, la facturación, la comunicación con pacientes, el intercambio de resultados con

laboratorios y la continuidad de consultas. El análisis se apoya en una arquitectura lógica de alto nivel, suficiente para identificar dependencias entre usuarios, red interna, SaaS clínico, correo, almacenamiento, copias de seguridad, proveedor TIC y conexión a Internet sin necesidad de realizar un inventario físico exhaustivo.

Usuarios inter-nos	Red corporativa	Servicios críticos	Terceros y soporte
Personal médico, enfermería, administración y dirección	Puestos de trabajo, red cableada, Wi-Fi corporativa y Wi-Fi de invitados	SaaS clínico, correo, almacenamiento documental, facturación y copias de seguridad	Proveedor TIC, laboratorios, aseguradoras y pacientes
Internet como canal de acceso a servicios cloud, comunicación externa y soporte remoto			

Figura 1: Arquitectura lógica de alto nivel del entorno SaludNova.

La Figura 1 sintetiza las dependencias principales del entorno de estudio. Su objetivo no es sustituir a un diagrama técnico detallado de red, sino mostrar los bloques que intervienen en el análisis: usuarios, infraestructura interna, servicios críticos y terceros. Esta representación permite entender por qué el análisis posterior considera riesgos asociados tanto a sistemas internos como a servicios cloud, comunicaciones externas y acceso remoto del proveedor TIC.

La arquitectura descrita muestra que SaludNova no es una organización tecnológicamente compleja en términos de infraestructura, pero sí altamente dependiente de un conjunto reducido de servicios críticos. La aplicación SaaS de gestión clínica concentra una parte esencial de la actividad: si no está disponible, el personal pierde acceso a historiales, agendas, informes y resultados. Esta concentración simplifica la operación diaria, pero también convierte al servicio en un punto de fallo relevante. Por ello, el análisis de riesgos debe valorar no solo ataques directos contra sistemas internos, sino también escenarios de indisponibilidad del proveedor, pérdida de conectividad o imposibilidad de trabajar con procedimientos alternativos.

Los puestos de trabajo actúan como interfaz principal entre los usuarios y los sistemas de información. Aunque los datos clínicos se encuentren en un servicio en la nube, un equipo comprometido puede permitir el robo de credenciales, el acceso a sesiones activas, la descarga de documentos o la propagación de malware hacia recursos compartidos. En este sentido, los equipos de consulta y recepción son activos operativos y, al mismo tiempo, superficies de exposición. La recepción es especialmente sensible porque combina atención al público, correo electrónico, llamadas, documentación administrativa y gestión de citas, lo que aumenta la probabilidad de errores y de exposición a phishing.

La coexistencia de red cableada, Wi-Fi corporativa y Wi-Fi de invitados introduce otro elemento de análisis. En una clínica, la conectividad inalámbrica para pacientes puede considerarse un servicio accesorio, pero si no se encuentra separada adecuadamente puede transformarse en una vía de acceso hacia sistemas internos. Por tanto, la segmentación de red no se plantea como una medida sofisticada, sino como una salvaguarda proporcional para separar entornos de confianza distintos. Esta decisión resulta coherente con el tamaño de SaludNova: no requiere una arqui-

itectura avanzada de gran organización, pero sí una separación mínima entre usuarios internos, pacientes y servicios críticos.

El correo electrónico corporativo y el almacenamiento documental conectan la actividad clínica con procesos administrativos y con terceros externos. Informes, consentimientos, facturas, resultados o comunicaciones con laboratorios circulan por estos canales. La seguridad del sistema, por tanto, no depende solo de proteger una base de datos clínica, sino de controlar el ciclo de vida de la información en distintos soportes y servicios. Este punto es esencial para comprender por qué los riesgos de fuga de información, envío erróneo y repositorio mal configurado forman parte del análisis, aunque no representen ataques técnicamente sofisticados.

3.3. Datos tratados y criticidad

La clínica trata datos personales identificativos, datos de contacto, información financiera y, especialmente, datos relativos a la salud. Estos últimos tienen una criticidad elevada por su impacto sobre la privacidad, la confianza del paciente y la prestación asistencial. Desde el punto de vista del RGPD, el tratamiento de categorías especiales de datos exige medidas reforzadas, una base jurídica adecuada, control de accesos, minimización, trazabilidad y capacidad de responder ante incidentes de seguridad [1, 7].

Tipo de dato	Ejemplos	Sensibilidad	Impacto potencial
Identificativos	Nombre, DNI, fecha de nacimiento, dirección, teléfono.	Media	Suplantación, fraude, exposición de identidad.
Clínicos	Diagnósticos, antecedentes, tratamientos, informes médicos.	Muy alta	Daño a la privacidad, discriminación, pérdida de confianza y posible afectación asistencial.
Pruebas diagnósticas	Resultados analíticos, imágenes, informes de exploración.	Muy alta	Decisiones clínicas incorrectas si se altera la integridad.
Administrativos	Citas, autorizaciones, consentimientos, comunicaciones.	Media-alta	Incumplimiento, conflictos con pacientes y errores operativos.

Facturación	Datos de pago, aseguradora, facturas y presupuestos.	Alta	Fraude, reclamaciones y perjuicio económico.
Credenciales	Usuarios, contraseñas, tokens y permisos.	Muy alta	Acceso no autorizado a sistemas y escalada de privilegios.

La clasificación anterior muestra que el valor de los datos no es homogéneo. Los datos identificativos y administrativos son necesarios para operar la clínica, pero los datos clínicos y las credenciales concentran la mayor criticidad. Los primeros afectan directamente a la privacidad y a la confianza del paciente; las segundas permiten acceder al resto de activos y pueden convertir un incidente aparentemente limitado en una brecha de mayor alcance. Esta relación explica por qué el análisis posterior no evalúa los activos de forma aislada, sino en función de sus dependencias: unas credenciales comprometidas pueden afectar a la aplicación clínica, al repositorio documental, al correo y a los historiales.

La información clínica también tiene una particularidad frente a otros datos empresariales: su sensibilidad no disminuye de forma significativa con el paso del tiempo. Una factura antigua puede perder relevancia operativa, pero un diagnóstico, un antecedente o un informe médico conservan valor personal y pueden generar perjuicios si se divulgan años después. Esta persistencia incrementa la responsabilidad de la clínica y justifica medidas de control sostenidas, no únicamente reacciones puntuales ante incidentes.

Además, los datos tratados participan directamente en procesos asistenciales. Un historial incompleto o inaccesible puede ralentizar una consulta; un informe alterado puede inducir a error; una agenda indisponible puede afectar a la continuidad del servicio; y una comunicación enviada al destinatario equivocado puede generar una brecha de confidencialidad. Por ello, la criticidad de la información no se deriva solo de su protección legal, sino también de su papel funcional dentro de la prestación sanitaria.

3.4. Supuestos y limitaciones del caso

El caso parte de cuatro supuestos principales. Primero, la clínica no cuenta con un equipo interno de ciberseguridad, por lo que las medidas deben ser asumibles por gerencia, personal administrativo y proveedor TIC. Segundo, no se evalúan dispositivos médicos complejos conectados, como equipamiento hospitalario especializado, para evitar ampliar excesivamente el alcance. Tercero, el análisis se centra en riesgos de seguridad de la información y protección de datos, no en continuidad clínica avanzada ni respuesta forense. Cuarto, las puntuaciones de riesgo se basan en

estimaciones razonadas, no en métricas históricas reales.

Estas limitaciones no reducen el valor académico del trabajo; al contrario, delimitan el proyecto y hacen posible aplicar una metodología completa de forma realista. El capítulo permite entender qué organización se analiza, qué sistemas son críticos, qué datos se protegen y por qué la gestión de riesgos es necesaria.

SaludNova constituye un objetivo realista para atacantes precisamente por su perfil intermedio. No posee la infraestructura de un hospital ni el volumen de datos de una gran aseguradora, pero concentra información sanitaria, actividad digital continua y recursos de seguridad limitados. Este tipo de organización puede resultar atractivo para campañas oportunistas de ransomware o phishing, en las que el atacante no selecciona necesariamente a la víctima por su tamaño, sino por la posibilidad de obtener credenciales, cifrar información crítica o presionar mediante la amenaza de interrupción del servicio. La dependencia de proveedores externos y la necesidad de mantener la actividad asistencial refuerzan esta exposición.

Esta caracterización también justifica que el análisis no se centre en amenazas extremadamente avanzadas, sino en escenarios plausibles y frecuentes para organizaciones pequeñas y medianas: credenciales comprometidas, malware, errores de configuración, copias de seguridad deficientes, accesos indebidos y fallos organizativos. La madurez del trabajo no depende de incorporar amenazas más sofisticadas, sino de analizar con profundidad aquellas que son más razonables para el caso y que pueden producir impactos relevantes sobre datos sensibles.

4. Metodología de análisis de riesgos

La metodología se inspira en NIST SP 800-30, que plantea el análisis de riesgos como un proceso estructurado de identificación de amenazas, vulnerabilidades, probabilidad, impacto y determinación del riesgo [10]. Para adecuarlo al alcance del TFG, se adopta una matriz semicuantitativa de Probabilidad $\times$ Impacto con escalas de 1 a 5. Esta decisión permite justificar los resultados con suficiente rigor sin exigir herramientas profesionales complejas ni datos estadísticos difíciles de obtener.

La elección de NIST SP 800-30 se justifica por su claridad conceptual, su orientación directa al análisis de amenazas y vulnerabilidades y su facilidad de adaptación a un caso de estudio académico. MAGERIT constituye una alternativa sólida y especialmente reconocible en el contexto español, pero su aplicación completa habría incrementado el nivel de detalle, el número de tablas y la carga documental del trabajo. Dado que el objetivo no es implantar una metodología corporativa exhaustiva, sino construir un análisis defendible y reproducible para una clínica ficticia, el enfoque basado en NIST resulta más proporcionado. ISO/IEC 27005 también se considera como referencia conceptual de gestión de riesgos, aunque en este TFG se utiliza principalmente la familia ISO 27001/27002/27799 para alinear controles y buenas prácticas.

4.1. Fases metodológicas

El proceso se divide en siete fases: delimitación del alcance, identificación de activos, identificación de amenazas, identificación de vulnerabilidades, estimación de probabilidad, estimación de impacto, cálculo del riesgo inherente y propuesta de tratamiento. Después se estima el riesgo residual tras aplicar controles.

1. **Alcance:** definición de la clínica, procesos, sistemas y datos incluidos.
2. **Activos:** inventario de información, software, hardware, servicios, personas e infraestructura.
3. **Amenazas:** eventos capaces de afectar a la confidencialidad, integridad o disponibilidad.
4. **Vulnerabilidades:** debilidades que facilitan la materialización de amenazas.
5. **Riesgo inherente:** valoración antes de controles adicionales.
6. **Tratamiento:** selección de controles técnicos, organizativos y normativos.
7. **Riesgo residual:** valoración posterior para comprobar la reducción obtenida.

La secuencia metodológica garantiza que el trabajo no enumere controles de forma aislada, sino que relacione cada medida con activos, amenazas, vulnerabilidades y niveles de riesgo previamente identificados.

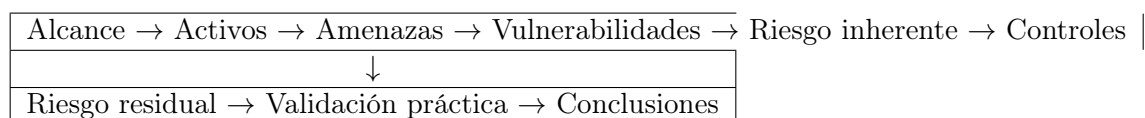


Figura 2: Flujo metodológico aplicado en el análisis de riesgos.

La Figura 2 muestra la continuidad entre la metodología y el resto de la memoria. El flujo parte de la delimitación del caso y finaliza con la validación práctica, de modo que los controles y las conclusiones se apoyan en riesgos previamente identificados y valorados. Esta secuencia refuerza la coherencia entre objetivos, análisis, plan de ciberseguridad y simulador.

4.2. Escalas de probabilidad e impacto

La probabilidad se valora de 1 a 5 considerando exposición, atractivo del activo, frecuencia de uso, existencia de vulnerabilidades y facilidad de explotación. El impacto se valora de 1 a 5 considerando consecuencias sobre confidencialidad, integridad, disponibilidad, cumplimiento normativo, reputación y continuidad del servicio.

Valor	Probabilidad	Criterio orientativo
1	Muy baja	Escenario poco plausible, controles sólidos y baja exposición.
2	Baja	Puede ocurrir, pero requiere condiciones específicas o errores acumulados.
3	Media	Escenario razonablemente posible en una clínica con medidas básicas.
4	Alta	Escenario probable por exposición frecuente, dependencia tecnológica o controles insuficientes.
5	Muy alta	Escenario muy probable o recurrente, con vulnerabilidades claras y explotación sencilla.

Valor	Impacto	Criterio orientativo
1	Muy bajo	Efecto menor, sin datos sensibles afectados ni interrupción relevante.
2	Bajo	Incidencia limitada, recuperable en poco tiempo y con impacto interno reducido.
3	Medio	Afectación operativa moderada, posible exposición limitada de datos o retraso asistencial.
4	Alto	Exposición de datos sensibles, interrupción relevante, perjuicio económico o notificación regulatoria probable.
5	Muy alto	Afectación grave a datos sanitarios, paralización del servicio, sanciones, daño reputacional severo o riesgo para pacientes.

4.3. Matriz de clasificación

El nivel de riesgo se calcula como $R = P \times I$, donde P es la probabilidad e I el impacto. La clasificación se realiza en cuatro niveles para facilitar la priorización.

Puntuación	Nivel	Decisión recomendada
1–4	Bajo	Aceptar o monitorizar.
5–9	Medio	Reducir si el coste es razonable.
10–16	Alto	Tratar con prioridad mediante controles definidos.
17–25	Crítico	Actuación urgente; no aceptar sin decisión formal de dirección.

Esta matriz es sencilla, pero suficiente para un TFG porque permite trazabilidad entre activos, amenazas, vulnerabilidades, controles y resultados. La metodología no pretende certificar un SGSI completo, sino construir una evaluación razonada y reproducible alineada con buenas prácticas.

4.4. Criterios de tratamiento del riesgo

Para cada riesgo se selecciona una estrategia: reducir, evitar, transferir o aceptar. En este TFG se prioriza la reducción mediante controles proporcionados, ya que la clínica debe seguir operando y no puede eliminar por completo su dependencia digital. La transferencia puede aplicarse mediante contratos, seguros o servicios externalizados, pero no elimina la responsabilidad de la clínica. La aceptación solo será válida para riesgos bajos o para riesgos residuales justificados y aprobados.

5. Análisis de riesgos del caso de estudio

En este capítulo se aplica la metodología al caso de Clínica SaludNova. El objetivo es obtener una visión priorizada de los riesgos que afectan al entorno y justificar posteriormente el plan de ciberseguridad.

5.1. Inventario de activos de información

ID	Activo	Categoría	Descripción	Criticidad
A1	Historias clínicas electrónicas	Información	Diagnósticos, antecedentes, informes, tratamientos y evolución clínica.	Muy alta
A2	Datos identificativos de pacientes	Información	Datos personales necesarios para admisión, contacto y gestión administrativa.	Alta
A3	Aplicación de gestión clínica	Software/SaaS	Plataforma central para agenda, historial, informes y resultados.	Muy alta
A4	Credenciales y permisos	Información/seguridad	Cuentas de personal, roles, contraseñas y accesos del proveedor TIC.	Muy alta
A5	Correo electrónico corporativo	Servicio	Comunicación con pacientes, laboratorios, proveedores y aseguradoras.	Alta
A6	Puestos de trabajo	Hardware	Equipos usados por médicos, enfermería y administración.	Alta

A7	Copias de seguridad	Servicio/información	Respaldo de información crítica y configuraciones.	Muy alta
A8	Red local y Wi-Fi	Infraestructura	Conectividad interna, acceso de personal y red de invitados.	Alta
A9	Documentación contractual y consentimientos	Información	Contratos, consentimientos informados y documentación legal.	Alta
A10	Personal de la clínica	Personas	Usuarios que tratan información y ejecutan procesos críticos.	Alta

5.2. Amenazas y vulnerabilidades

Las amenazas más relevantes son ransomware, phishing, acceso no autorizado, fuga de información, error humano, pérdida de disponibilidad del SaaS, compromiso del proveedor TIC, uso indebido de privilegios, pérdida de dispositivos y configuración insegura de red. Estas amenazas son realistas para una clínica pequeña porque combinan datos valiosos, exposición a correo electrónico, dependencia de terceros y madurez limitada.

Amenaza	Escenario	Vulnerabilidades asociadas
Ransomware	Cifrado de equipos o documentos tras ejecutar un adjunto malicioso.	Formación insuficiente, copias no verificadas, permisos excesivos, falta de segmentación.
Phishing	Robo de credenciales mediante correo que simula proveedor, aseguradora o plataforma clínica.	Ausencia de MFA, baja concienciación, filtros de correo básicos.
Acceso no autorizado	Entrada a la aplicación clínica con credenciales válidas comprometidas.	Contraseñas débiles, cuentas compartidas, revisión insuficiente de permisos.
Fuga de información	Envío de informe al destinatario incorrecto o almacenamiento en repositorio mal configurado.	Procedimientos poco claros, falta de doble verificación, permisos amplios.
Indisponibilidad del SaaS	Caída del proveedor o pérdida de conectividad que impide consultar historiales.	Ausencia de procedimiento manual, dependencia de Internet, falta de acuerdos de nivel de servicio revisados.

Compromiso del proveedor TIC	Uso indebido o compromiso de acceso remoto de mantenimiento.	Acceso persistente, falta de registro, MFA no obligatorio, contrato de tratamiento insuficiente.
------------------------------	--	--

5.3. Matriz de riesgos inherentes

ID	Riesgo	Activo afectado	Vulnerabilidad principal	P	I	Nivel
R1	Ransomware en puestos internos	A1, A6, A7	Formación insuficiente y copias no probadas	4	5	Crítico (20)
R2	Robo de credenciales por phishing	A3, A4, A5	Ausencia de MFA y concienciación limitada	4	5	Crítico (20)
R3	Acceso indebido a historias clínicas	A1, A3, A4	Permisos excesivos y revisión escasa	3	5	Alto (15)
R4	Fuga por envío erróneo de informes	A1, A2, A5	Procedimiento de verificación insuficiente	3	4	Alto (12)
R5	Indisponibilidad de aplicación SaaS	A3	Dependencia del proveedor e Internet	3	4	Alto (12)
R6	Copias de seguridad no recuperables	A7	Pruebas de restauración inexistentes	3	5	Alto (15)
R7	Movimiento lateral desde Wi-Fi invitados	A6, A8	Segmentación incompleta	3	4	Alto (12)
R8	Compromiso del acceso remoto del proveedor	A3, A4, A8	Acceso remoto persistente sin registro suficiente	3	5	Alto (15)
R9	Pérdida o robo de portátil	A1, A2, A6	Cifrado y borrado remoto no garantizados	2	4	Medio (8)
R10	Error de configuración en repositorio documental	A1, A9	Permisos por defecto demasiado amplios	3	4	Alto (12)

Los riesgos prioritarios son R1, R2, R3, R6 y R8 porque combinan impacto muy alto con probabilidad media o alta. La conclusión principal de esta fase es que la clínica no necesita controles sofisticados de alto coste como primera medida, sino controles básicos bien implantados: MFA,

copias verificadas, mínimo privilegio, segmentación, formación, procedimientos y control del proveedor.

La priorización se representa mediante una matriz 5x5 y una comparación entre riesgo inherente y riesgo residual. Esta visualización permite identificar de forma inmediata qué riesgos requieren tratamiento prioritario y comprobar posteriormente el efecto de los controles seleccionados.

El riesgo R1, relativo al ransomware en puestos internos, se valora como crítico porque combina una probabilidad alta con un impacto muy alto. Su origen más plausible se encuentra en la interacción entre usuarios y canales de entrada habituales, especialmente correo electrónico, navegación web y descarga de documentos. En una clínica como SaludNova, los puestos de recepción y administración están expuestos a comunicaciones constantes con pacientes, laboratorios, aseguradoras y proveedores, lo que aumenta la probabilidad de recibir adjuntos maliciosos o enlaces fraudulentos. A diferencia de otros incidentes más localizados, el ransomware puede propagarse desde un único equipo hacia unidades compartidas, documentos clínicos o recursos accesibles con las credenciales del usuario comprometido.

La probabilidad asignada a R1 se considera alta porque existen factores predisponentes razonables: formación limitada del personal, dependencia de puestos Windows, uso intensivo del correo, permisos posiblemente amplios y ausencia inicial de pruebas de restauración suficientemente formalizadas. No se asigna probabilidad máxima porque el escenario presupone la existencia de algunas medidas básicas, como antivirus y copias periódicas, pero dichas medidas no son suficientes por sí solas para descartar el incidente. El impacto se valora como muy alto porque un cifrado de información crítica podría impedir el acceso a historiales, informes, agendas o documentación necesaria para la actividad diaria. Además, un ataque de ransomware moderno puede incluir exfiltración previa de datos, lo que afectaría simultáneamente a disponibilidad y confidencialidad. La puntuación 20 refleja, por tanto, un escenario prioritario y coherente con la realidad de organizaciones sanitarias pequeñas o medianas.

El riesgo R2, robo de credenciales por phishing, también se clasifica como crítico. Su origen se sitúa en la explotación del factor humano mediante correos que simulan comunicaciones legítimas: avisos del proveedor de la aplicación clínica, notificaciones de correo, mensajes de aseguradoras, solicitudes de pacientes o supuestas incidencias técnicas. Este riesgo resulta especialmente relevante porque las credenciales son un activo transversal: una cuenta comprometida puede servir para acceder al SaaS clínico, al correo, al repositorio documental o incluso a herramientas de soporte remoto si existen permisos suficientes.

La probabilidad de R2 se valora como alta porque el phishing es una amenaza frecuente, escalable y de bajo coste para el atacante. En SaludNova, la exposición del personal administrativo y sanitario a comunicaciones externas incrementa esta probabilidad. La ausencia inicial de autenticación multifactor y una concienciación limitada hacen que el robo de credenciales sea un escenario razonablemente probable. El impacto se valora como muy alto porque el uso de credenciales legítimas puede retrasar la detección, permitir consultas indebidas de datos clínicos, facilitar movimientos laterales y comprometer la trazabilidad. La puntuación crítica no implica

que el incidente sea inevitable, sino que la combinación de facilidad de ataque e impacto potencial exige tratamiento prioritario.

El riesgo R3, acceso indebido a historias clínicas, tiene una naturaleza distinta. No depende necesariamente de un ataque externo, sino de una gestión insuficiente de permisos, roles demasiado amplios o ausencia de revisiones periódicas. En una clínica pequeña puede existir la tendencia a conceder accesos amplios para evitar bloqueos operativos, especialmente cuando el personal necesita responder con rapidez a pacientes o resolver incidencias administrativas. Sin embargo, esa flexibilidad incrementa la posibilidad de que un usuario consulte información que no necesita para su función, o de que una cuenta comprometida tenga acceso a más datos de los estrictamente necesarios.

La probabilidad de R3 se estima media porque requiere una combinación de permisos inadecuados, ausencia de control o uso indebido de cuentas, pero no depende de técnicas avanzadas. El impacto se valora como muy alto porque afecta directamente al activo más sensible del caso de estudio: la historia clínica. Incluso si no se produce alteración de datos, una consulta indebida puede constituir una vulneración grave de la confidencialidad y generar consecuencias legales, éticas y reputacionales. La puntuación 15 refleja que no se trata del escenario más probable en términos de frecuencia, pero sí de un riesgo que debe tratarse con prioridad por la sensibilidad del activo afectado.

El riesgo R6, copias de seguridad no recuperables, se incluye entre los prioritarios porque afecta a la capacidad real de recuperación de la clínica. La existencia de copias no garantiza por sí misma la continuidad; si las copias no se prueban, no están aisladas, no cubren todos los datos críticos o dependen del mismo entorno comprometido, pueden resultar inútiles en el momento del incidente. En el contexto de SaludNova, este riesgo se relaciona especialmente con ransomware, borrados accidentales, fallos del proveedor o errores de configuración en repositorios documentales.

La probabilidad se valora como media porque muchas organizaciones pequeñas realizan copias periódicas, pero no siempre verifican restauraciones ni documentan tiempos de recuperación. No se asume que las copias sean inexistentes, sino que su eficacia no está demostrada. El impacto se valora como muy alto porque una copia no recuperable convierte un incidente técnico en una interrupción operativa grave. La clínica podría perder acceso a documentación, configuraciones o información necesaria para reanudar la actividad. En este caso, la puntuación 15 se justifica porque el riesgo no reside en sufrir un ataque, sino en no poder recuperarse de él de forma fiable.

El riesgo R8, compromiso del acceso remoto del proveedor, es especialmente relevante por la externalización del soporte TIC. Su origen puede estar en credenciales del proveedor comprometidas, sesiones remotas mal protegidas, accesos persistentes, ausencia de registro o falta de limitación temporal. En organizaciones pequeñas, el proveedor suele concentrar capacidades técnicas que internamente no existen, lo que convierte su cuenta o canal de acceso en un punto de alto privilegio. Si dicho acceso se compromete, el atacante puede operar con permisos elevados y con conocimiento de la infraestructura.

La probabilidad de R8 se valora como media porque requiere comprometer un canal concreto, pero la dependencia del proveedor y la posible ausencia de controles robustos lo hacen plausible. El impacto es muy alto porque el acceso remoto puede permitir modificar configuraciones, acceder a sistemas internos, desactivar protecciones o afectar a copias de seguridad. Además, este riesgo tiene una dimensión contractual y de responsabilidad: aunque el proveedor intervenga técnicamente, la clínica continúa siendo responsable de proteger los datos que trata. La puntuación 15 refleja la necesidad de gestionar la seguridad de terceros como parte integral del plan, no como un aspecto administrativo secundario.

En conjunto, los riesgos prioritarios muestran que la exposición de SaludNova no depende de un único fallo técnico. El patrón común es la combinación de activos sensibles, usuarios con necesidades operativas legítimas, dependencia de servicios digitales y controles iniciales insuficientemente formalizados. Por ello, el tratamiento debe ser equilibrado: controles técnicos para reducir exposición, controles organizativos para mejorar comportamientos y procedimientos, y controles de cumplimiento para reforzar responsabilidades y trazabilidad.

No todas las amenazas posibles se incorporan al análisis principal. Se excluyen dispositivos médicos complejos conectados porque el caso se centra en una clínica ambulatoria con pruebas diagnósticas básicas, no en un entorno hospitalario con equipamiento electromédico avanzado. Incluir este tipo de dispositivos obligaría a analizar protocolos específicos, mantenimiento clínico, certificaciones, seguridad del fabricante y riesgos de seguridad del paciente que exceden el alcance de un TFG de 15 ECTS.

Tampoco se realiza pentesting ni auditoría técnica real, ya que no existe una infraestructura productiva sobre la que ejecutar pruebas y el objetivo del trabajo no es descubrir vulnerabilidades mediante explotación. Incorporar pentesting desplazaría el enfoque desde la gestión de riesgos hacia la seguridad ofensiva, exigiría autorización formal, entorno controlado y evidencias técnicas que no forman parte del caso ficticio. Del mismo modo, no se desarrolla un análisis forense, porque este requiere la existencia de un incidente real o simulado con evidencias, líneas temporales, adquisición de soportes y procedimientos de preservación que no son necesarios para diseñar un plan preventivo.

El Esquema Nacional de Seguridad tampoco se adopta como marco principal porque SaludNova se define como una clínica privada ficticia y el trabajo ya dispone de un conjunto suficiente de referencias mediante RGPD, LOPDGDD, NIST e ISO. Introducir ENS ampliaría el análisis hacia categorización de sistemas, medidas específicas del sector público y cumplimiento normativo adicional. Esta exclusión no resta solidez al TFG; al contrario, evita solapamientos y mantiene el foco en una organización privada con datos sensibles.

Finalmente, no se estudian APT avanzadas ni campañas altamente dirigidas porque no serían proporcionales al perfil de SaludNova ni al objetivo del trabajo. Aunque ninguna organización está completamente exenta de amenazas sofisticadas, el análisis debe priorizar escenarios plausibles, tratables y coherentes con los recursos disponibles. Para una clínica pequeña o mediana, la mayor madurez académica no consiste en enumerar amenazas extremas, sino en justificar con

precisión aquellas que combinan probabilidad razonable, impacto elevado y controles viables.

6. Diseño del plan de ciberseguridad

El plan de ciberseguridad se organiza en medidas técnicas, organizativas y de cumplimiento. Su diseño se alinea con ISO/IEC 27001 como marco de gestión, ISO/IEC 27002 como catálogo de controles, ISO 27799 como referencia sectorial sanitaria y RGPD como marco legal de protección de datos [1, 3, 4, 6]. El objetivo no es implantar una certificación completa, sino seleccionar controles proporcionados al tamaño y riesgo de la clínica.

6.1. Controles seleccionados y alineación normativa

ID	Control	Riesgos tratados	Alineación	Prioridad
C1	Implantar autenticación multifactor en correo, SaaS clínico y acceso remoto.	R2, R3, R8	ISO 27001/27002: control de acceso; RGPD: seguridad del tratamiento.	Alta
C2	Revisar roles y aplicar mínimo privilegio en la aplicación clínica y repositorios.	R3, R10	ISO 27002: gestión de identidades; ISO 27799: acceso a información sanitaria.	Alta
C3	Establecer copias 3-2-1, copia offline/inmutable y prueba mensual de restauración.	R1, R6	ISO 27002: backup; ISO 27001: continuidad; ISO 27799.	Alta
C4	Segmentar red interna, Wi-Fi corporativa y Wi-Fi de invitados.	R1, R7	ISO 27002: seguridad de redes.	Media-alta
C5	Formación trimestral en phishing, tratamiento de datos y notificación de incidentes.	R1, R2, R4	ISO 27002: concienciación; RGPD: medidas organizativas.	Alta
C6	Procedimiento de envío seguro de informes y doble verificación de destinatarios.	R4	RGPD: confidencialidad, integridad y minimización.	Alta

C7	Registro y revisión de accesos a historias clínicas y cuentas privilegiadas.	R3, R8	ISO 27002: logging; ISO 27799: trazabilidad sanitaria.	Media-alta
C8	Endpoints actualizados con EDR/antimalware, cifrado de disco y bloqueo automático.	R1, R9	ISO 27002: protección frente a malware y dispositivos finales.	Media-alta
C9	Formalizar contratos con proveedores, DPA, SLA y requisitos de seguridad.	R5, R8	RGPD: encargado del tratamiento; ISO 27001: relación con proveedores.	Alta
C10	Plan básico de respuesta a incidentes con contactos, criterios de escalado y plantilla de registro.	R1–R10	ISO 27001/27002: gestión de incidentes; RGPD: notificación de brechas.	Alta

La autenticación multifactor constituye el control técnico de mayor prioridad inicial porque actúa sobre uno de los vectores más transversales del análisis: el compromiso de credenciales. Su aplicación en correo, SaaS clínico y acceso remoto reduce de forma directa la probabilidad de R2, R3 y R8, ya que una contraseña robada deja de ser suficiente para acceder a sistemas críticos. También limita el impacto potencial de campañas de phishing, puesto que dificulta que una cuenta comprometida se convierta automáticamente en acceso efectivo a historiales o repositorios. Su coste organizativo es moderado: requiere configuración, formación básica y gestión de incidencias por pérdida de segundo factor, pero no exige rediseñar la infraestructura. Para SaludNova es una medida especialmente viable porque protege servicios concretos y de alto valor sin necesidad de implantar una solución compleja.

El principio de mínimo privilegio complementa al MFA porque reduce el alcance de una cuenta legítima o comprometida. Su objetivo no es impedir todo acceso, sino asegurar que cada perfil disponga únicamente de los permisos necesarios para su función. En SaludNova, este control mitiga R3 y R10 al limitar consultas indebidas a historias clínicas y accesos excesivos al repositorio documental. También reduce el impacto de R2, ya que una credencial robada con permisos limitados produce menos daño que una cuenta con acceso amplio. Su principal limitación es organizativa: exige definir roles, revisar permisos periódicamente y gestionar excepciones sin bloquear la actividad asistencial. No obstante, el tamaño de la clínica hace que esta revisión sea asumible si se plantea de forma gradual y vinculada a perfiles funcionales claros.

Las copias de seguridad verificadas son el control principal frente a R1 y R6. Su valor no reside únicamente en disponer de una copia, sino en poder restaurarla en un tiempo aceptable y con una integridad suficiente. Una estrategia 3-2-1, junto con copias offline o inmutables y pruebas periódicas de restauración, reduce el impacto de ransomware, borrado accidental o fallo de pro-

veedor. También reduce parcialmente la probabilidad de que un incidente derive en paralización prolongada, porque introduce disciplina operativa y detección de fallos en el proceso de respaldo. Su coste puede ser superior al de otros controles, ya que requiere almacenamiento, planificación, tiempo de prueba y documentación, pero resulta proporcionado al impacto que tendría la pérdida de información clínica o administrativa.

La segmentación de red mitiga especialmente R1 y R7. En una organización pequeña, la red tiende a configurarse por simplicidad, pero esa simplicidad puede facilitar movimientos laterales si un equipo se compromete o si la Wi-Fi de invitados no está correctamente separada. La segmentación no elimina el riesgo de malware ni sustituye la protección de endpoints, pero limita la propagación y reduce el impacto potencial. Para SaludNova, una separación básica entre red corporativa, red de invitados, sistemas administrativos y recursos críticos ofrece una mejora razonable sin exigir una arquitectura de gran complejidad. La principal limitación es que requiere una configuración correcta y mantenimiento por parte del proveedor TIC; si no se documenta adecuadamente, puede generar problemas operativos o falsas sensaciones de seguridad.

La formación del personal es imprescindible porque varios riesgos prioritarios tienen un componente humano. R1, R2 y R4 dependen en gran medida de decisiones cotidianas: abrir un adjunto, introducir credenciales, enviar un informe, comunicar una incidencia o verificar un destinatario. La formación reduce la probabilidad al mejorar la capacidad de identificar señales de phishing, comprender la sensibilidad de los datos y aplicar procedimientos. También reduce el impacto porque favorece una notificación temprana de incidentes. Su coste económico es bajo comparado con controles técnicos avanzados, pero exige continuidad. Una sesión aislada no transforma comportamientos; por ello, se plantea formación periódica, breve y adaptada a situaciones reales de la clínica.

La gestión de proveedores es un control clave para R5 y R8. En SaludNova, el proveedor TIC y el proveedor SaaS no son elementos externos al riesgo, sino partes del sistema de información extendido. Formalizar contratos, acuerdos de nivel de servicio, requisitos de seguridad, obligaciones de confidencialidad y condiciones de acceso remoto reduce la probabilidad de intervenciones inseguras y mejora la capacidad de exigir responsabilidades. También reduce el impacto, ya que establece canales de escalado y compromisos de recuperación ante incidencias. Su limitación principal es que la clínica puede tener capacidad negociadora limitada frente a proveedores grandes; aun así, puede documentar requisitos mínimos, revisar accesos y seleccionar servicios que ofrezcan garantías razonables.

El plan básico de respuesta a incidentes actúa de forma transversal sobre todos los riesgos. No evita por sí mismo que ocurra un incidente, pero reduce el impacto al ordenar la reacción: quién toma decisiones, a quién se avisa, qué sistemas se aíslan, cómo se documenta el evento y cuándo se escala a asesoría legal o proveedor TIC. En un entorno pequeño, la ausencia de procedimiento puede provocar retrasos, pérdida de evidencias, comunicaciones contradictorias o decisiones improvisadas. Su coste es bajo y su viabilidad alta, porque puede materializarse en un documento breve con contactos, criterios de gravedad, pasos iniciales y plantillas de registro. La limitación es que debe probarse mediante simulacros sencillos; de lo contrario, puede quedar

como documentación formal sin utilidad real.

La combinación de controles seleccionados responde a una lógica de defensa en profundidad proporcionada al caso. No se busca implantar controles sofisticados por acumulación, sino cubrir las debilidades que explican los riesgos prioritarios: credenciales, permisos, recuperación, segmentación, comportamiento de usuarios, terceros y respuesta. Esta selección mantiene el equilibrio entre viabilidad y reducción de riesgo, aspecto especialmente importante en una clínica que no dispone de equipo interno especializado ni presupuesto equivalente al de una gran organización sanitaria.

6.2. Hoja de ruta de implantación

Fase	Acciones	Resultado
0–1 mes	Activar MFA, revisar cuentas, eliminar usuarios obsoletos, verificar copias existentes y documentar contactos de incidente.	Reducción inmediata de exposición ante phishing, accesos indebidos y ransomware.
1–3 meses	Definir roles, aplicar mínimo privilegio, formar al personal, aprobar procedimiento de envío de informes y formalizar requisitos con proveedor TIC.	Mejora de control organizativo y cumplimiento.
3–6 meses	Segmentar red, implantar pruebas periódicas de restauración, centralizar registros relevantes y revisar configuración del repositorio documental.	Mayor resiliencia y capacidad de detección.
6–12 meses	Realizar simulacro de incidente, revisar métricas, actualizar matriz de riesgos y valorar mejoras adicionales.	Ciclo de mejora continua y evidencias para auditoría interna.

6.3. Indicadores de reducción del riesgo

Para medir la eficacia del plan se definen indicadores simples, medibles y adecuados al tamaño de la clínica. No se busca una monitorización avanzada, sino evidencias objetivas que permitan comprobar si el riesgo disminuye.

Indicador	Medición	Valor inicial estimado	Objetivo
Cobertura MFA	Porcentaje de cuentas críticas con MFA activo.	20 %	100 % en 1 mes.
Pruebas de restauración	Restauraciones verificadas al mes.	0	1 mensual documentada.

Cuentas obsoletas	Número de cuentas activas sin usuario vigente.	5	0.
Tasa de clic en simulación phishing	Porcentaje de usuarios que hacen clic en correo simulado.	25 %	Menos del 10 %.
Tiempo de revocación de accesos	Días desde baja/cambio de rol hasta revocación.	7 días	Menos de 24 horas.
Incidentes sin registrar	Incidencias comunicadas informalmente sin ticket o acta.	Alto	0 incidentes sin registro.
Equipos cifrados y actualizados	Porcentaje de endpoints con cifrado y parches al día.	60 %	95 % o superior.

6.4. Riesgo residual estimado

Tras aplicar los controles, se reevalúan probabilidad e impacto. En la mayoría de casos los controles reducen principalmente la probabilidad; en otros, como copias verificadas y respuesta a incidentes, también reducen el impacto al mejorar la recuperación.

La estimación del riesgo residual debe interpretarse con cautela. La aplicación de controles no elimina las amenazas ni garantiza que el incidente no pueda ocurrir; lo que modifica es la exposición de la clínica y su capacidad de limitar consecuencias. Por ejemplo, MFA no elimina el phishing, pero reduce la probabilidad de que una contraseña robada permita acceder a sistemas críticos. Las copias verificadas no impiden el ransomware, pero reducen el impacto operativo si la restauración es posible. La segmentación no evita que un equipo se infecte, pero limita la propagación. Esta diferencia entre mitigación y eliminación es esencial para evitar una lectura excesivamente optimista del plan.

La reducción de riesgo se produce de dos formas. En algunos casos disminuye principalmente la probabilidad, como ocurre con MFA, formación o mínimo privilegio. En otros, disminuye sobre todo el impacto, como sucede con copias de seguridad, respuesta a incidentes o acuerdos con proveedores. Determinados controles actúan sobre ambas dimensiones: una política de acceso remoto con MFA, registro y limitación temporal reduce la probabilidad de compromiso y, si el incidente se produce, facilita la detección y contención. Por este motivo, la reevaluación residual no debe entenderse como un cálculo mecánico, sino como una estimación razonada basada en el efecto esperado de los controles.

La aceptación del riesgo residual es una decisión de dirección, no únicamente técnica. El proveedor TIC puede recomendar medidas, y el responsable de protección de datos puede advertir de obligaciones legales, pero la clínica debe decidir qué nivel de riesgo considera asumible en función de su actividad, recursos y responsabilidad sobre los pacientes. Esta aceptación debe do-

cumentarse, especialmente cuando un riesgo permanece en nivel medio. En SaludNova, aceptar riesgos residuales medios puede ser razonable si existen controles implantados, procedimientos de seguimiento y un calendario de revisión. Lo que no sería defendible es aceptar riesgos altos o críticos sin tratamiento ni justificación formal.

La revisión periódica es necesaria porque el riesgo residual no permanece estable. Cambios en proveedores, incorporación de nuevos servicios, rotación de personal, aparición de vulnerabilidades, modificación de procesos o aumento del volumen de pacientes pueden alterar la probabilidad y el impacto. Por ello, la matriz debe revisarse al menos anualmente y siempre que se produzcan cambios relevantes en el sistema de información. Esta revisión no implica rehacer el TFG ni implantar un SGSI completo, sino mantener la coherencia del análisis y comprobar si los controles siguen siendo proporcionados.

El resultado residual también permite priorizar mejoras futuras. Los riesgos que quedan en nivel medio, como R1, R2, R3 y R8, no deben interpretarse como resueltos definitivamente, sino como controlados de forma razonable dentro del alcance del plan. Si la clínica dispusiera de más recursos, podría reforzar monitorización, automatizar registros, realizar simulacros más frecuentes o introducir soluciones avanzadas de detección. Sin embargo, para el contexto definido, la reducción de crítico o alto a medio o bajo representa una mejora sustancial y defendible.

ID	Riesgo	P ini.	I ini.	Nivel inicial	P res.	I res.	Nivel residual
R1	Ransomware en puestos internos	4	5	Crítico 20	2	4	Medio 8
R2	Robo de credenciales por phishing	4	5	Crítico 20	2	4	Medio 8
R3	Acceso indebido a historias clínicas	3	5	Alto 15	2	4	Medio 8
R4	Fuga por envío erróneo de informes	3	4	Alto 12	2	3	Medio 6
R5	Indisponibilidad de aplicación SaaS	3	4	Alto 12	2	3	Medio 6
R6	Copias no recuperables	3	5	Alto 15	1	4	Bajo 4
R7	Movimiento lateral desde Wi-Fi invitados	3	4	Alto 12	1	3	Bajo 3
R8	Compromiso del acceso remoto del proveedor	3	5	Alto 15	2	4	Medio 8
R9	Pérdida o robo de portátil	2	4	Medio 8	1	3	Bajo 3
R10	Repositorio documental mal configurado	3	4	Alto 12	2	3	Medio 6

La reevaluación muestra una reducción de los riesgos críticos a niveles medios y de varios riesgos altos a niveles bajos o medios. El riesgo no desaparece, pero queda más controlado, documentado

y aceptable para una clínica de tamaño pequeño-medio. La aceptación del riesgo residual debe quedar aprobada por dirección y revisarse periódicamente.

7. Pequeña validación práctica

La parte práctica del trabajo se concreta en un simulador académico de análisis de riesgos desarrollado en Python. Esta implementación no modifica la metodología definida en los capítulos anteriores ni amplía el alcance del TFG hacia un proyecto software. Su función es más concreta: comprobar que el análisis realizado sobre la clínica SaludNova puede expresarse en datos estructurados, reproducirse mediante reglas explícitas y visualizarse de forma comprensible. Por tanto, el simulador actúa como mecanismo de validación metodológica, no como herramienta profesional de ciberseguridad.

La validación se sitúa al final de la cadena lógica del trabajo. En primer lugar, los capítulos iniciales plantean el problema de proteger datos sanitarios en un entorno eHealth. A continuación, el marco teórico justifica la necesidad de aplicar una metodología de análisis de riesgos basada en NIST SP 800-30 y en una matriz Probabilidad $\times$ Impacto. Posteriormente, el caso de estudio SaludNova permite identificar activos, amenazas y vulnerabilidades. Sobre esa base se calculan los riesgos inherentes, se diseña un plan de controles y se estima el riesgo residual. El simulador toma precisamente esos resultados y los transforma en una comprobación automatizada de coherencia: lee los riesgos definidos, recalcula las puntuaciones, genera una tabla de resultados y produce figuras que permiten interpretar la reducción obtenida.

Esta decisión refuerza la dimensión aplicada del TFG sin convertirlo en un desarrollo software complejo. La aportación práctica no consiste en construir una aplicación comercial, desplegar una plataforma, crear una base de datos o implementar mecanismos técnicos de defensa. Consiste en demostrar que el modelo de análisis es reproducible. Esta reproducibilidad es importante porque evita que la matriz de riesgos sea únicamente una tabla estática dentro de la memoria. Al automatizar el cálculo, cualquier modificación razonada en la probabilidad, el impacto o el riesgo residual puede recalcularse de forma inmediata, manteniendo la trazabilidad entre metodología, análisis, controles y resultados.

7.1. Objetivo y finalidad de la validación

El objetivo principal de la validación es verificar que las puntuaciones obtenidas en el análisis de riesgos responden a una regla común y que la reducción del riesgo tras aplicar controles puede observarse de forma sistemática. Para ello, el simulador parte de los diez riesgos definidos en el capítulo de análisis, calcula el riesgo inherente, calcula el riesgo residual, determina la reducción absoluta y porcentual, clasifica los niveles de riesgo y genera resultados gráficos.

Desde el punto de vista académico, la validación cumple tres funciones. La primera es reforzar la transparencia del análisis. Cada riesgo se representa mediante datos explícitos: identificador,

descripción, probabilidad inicial, impacto inicial, probabilidad residual e impacto residual. La segunda función es mejorar la consistencia interna del trabajo. Al aplicar la misma fórmula a todos los riesgos, se reduce la posibilidad de que algunas puntuaciones se interpreten de manera diferente. La tercera función es facilitar la interpretación de los resultados. Las figuras generadas permiten observar rápidamente qué riesgos concentran mayor exposición inicial, cuáles se reducen con más intensidad y qué riesgos permanecen como residuales relevantes.

La finalidad del simulador, por tanto, no es sustituir el juicio experto ni demostrar empíricamente que los controles funcionen en un entorno real. La clínica SaludNova es un caso ficticio y las puntuaciones proceden de una valoración razonada, no de datos históricos de incidentes. No obstante, una vez aceptadas dichas puntuaciones como parte del caso de estudio, el simulador aporta evidencia de que el tratamiento de los datos es ordenado, repetible y coherente con la metodología descrita. Esto resulta especialmente útil en un TFG, donde la defensa debe mostrar no solo que se han propuesto controles adecuados, sino también que existe una conexión verificable entre diagnóstico inicial, tratamiento y resultado residual.

7.2. Proceso seguido

El proceso de validación comienza con el archivo `riesgos.csv`, que contiene los riesgos R1–R10 ya definidos en la memoria. Cada fila representa un riesgo y recoge los valores necesarios para aplicar la matriz Probabilidad $\times$ Impacto: probabilidad inicial, impacto inicial, riesgo inicial, probabilidad residual, impacto residual y riesgo residual. Esta estructura reproduce el razonamiento seguido en los capítulos anteriores, pero lo expresa en un formato legible por el simulador.

La elección de un fichero CSV responde a criterios de sencillez, transparencia y reproducibilidad. Se trata de un formato tabular abierto, fácilmente revisable con un editor de texto, una hoja de cálculo o una herramienta de análisis de datos. En el contexto del TFG, esta decisión evita depender de una base de datos o de una interfaz específica y permite que el foco permanezca en la metodología de gestión de riesgos. Además, el CSV facilita la trazabilidad: cada fila puede vincularse directamente con un riesgo descrito en la matriz, y cada columna representa un elemento necesario para calcular o interpretar el nivel de exposición.

A partir de ese archivo, el simulador realiza el cálculo automático del riesgo inherente mediante la fórmula $R = P \times I$. Aunque el archivo de entrada ya incluye valores iniciales y residuales, el cálculo automatizado permite comprobar que la puntuación final se obtiene de forma consistente. A continuación, se calcula la reducción absoluta, entendida como la diferencia entre riesgo inherente y riesgo residual, y la reducción porcentual, que permite comparar riesgos con puntuaciones iniciales diferentes. Finalmente, los resultados se guardan en `riesgos_resultado.csv`, de modo que la salida de la validación queda documentada y puede revisarse de forma independiente.

Además del archivo de resultados, el simulador genera tres figuras: `barras.png`, `heatmap.png` y `reduccion.png`. Estas figuras no se incorporan como elementos decorativos, sino como evidencias de interpretación. El gráfico de barras compara el riesgo inherente y residual de cada escenario;

el mapa de calor muestra la concentración inicial de riesgos según probabilidad e impacto; y el gráfico de reducción porcentual permite evaluar qué controles producen una disminución más intensa del riesgo estimado.

La lógica del proceso seguido puede resumirse de la siguiente forma:

Elemento	Descripción
Entrada	Archivo <code>riesgos.csv</code> con los diez riesgos del caso SaludNova y sus valores iniciales y residuales.
Procesamiento	Aplicación automática de la fórmula $R = P \times I$, cálculo de reducción absoluta, cálculo de reducción porcentual y clasificación por nivel.
Salida tabular	Archivo <code>riesgos_resultado.csv</code> , que documenta el resultado del análisis automatizado.
Salida gráfica	Generación de <code>barras.png</code> , <code>heatmap.png</code> y <code>reduccion.png</code> para facilitar la interpretación de los resultados.
Finalidad	Validar la reproducibilidad del análisis y reforzar la continuidad entre matriz de riesgos, controles y riesgo residual.

7.3. Implementación del simulador

La implementación se ha realizado en Python por tratarse de un lenguaje ampliamente utilizado en análisis de datos, automatización y prototipado académico. Su elección es coherente con el alcance del TFG porque permite procesar información tabular y generar visualizaciones sin necesidad de construir una aplicación compleja. El objetivo no es evaluar la calidad del software desarrollado, sino utilizar un medio sencillo para validar el modelo de análisis.

Python también resulta adecuado porque permite representar de forma directa las operaciones metodológicas descritas en el trabajo. La matriz de riesgos se traduce en una tabla de datos; la fórmula $R = P \times I$ se convierte en un cálculo automático; la clasificación de niveles se aplica de manera homogénea; y las salidas gráficas se generan a partir de los mismos valores. Esta correspondencia entre metodología y automatización es lo que aporta valor académico a la práctica. No se añade una lógica nueva, sino que se ejecuta de forma controlada la lógica ya definida en los capítulos anteriores.

La biblioteca `pandas` se utiliza para leer el archivo `riesgos.csv`, representar los riesgos como una tabla de datos y calcular nuevas columnas de resultado. Desde una perspectiva metodológica, esto permite tratar la matriz de riesgos como un conjunto estructurado de observaciones. Cada fila mantiene la relación entre el identificador del riesgo, su descripción y sus valores de probabilidad e impacto. La ventaja principal es que el cálculo deja de depender de operaciones manuales dispersas en el documento y pasa a ejecutarse de manera uniforme sobre todos los riesgos.

La biblioteca `matplotlib` se emplea para generar las figuras incluidas en la memoria. Su uso res-

ponde a la necesidad de convertir los resultados numéricos en evidencias visuales interpretables. En un análisis de riesgos, las tablas son necesarias, pero no siempre permiten apreciar de forma inmediata la concentración de exposición o la magnitud relativa de la reducción. Las visualizaciones ayudan a cerrar esa brecha: muestran de forma directa qué riesgos eran más relevantes antes del tratamiento y cómo cambia la situación tras aplicar controles.

```

simulador.py > ...
9  print("\n=====")
10  print("    SIMULADOR DE ANÁLISIS DE RIESGOS")
11  print("        Clínica SaludNova")
12  print("=====\\n")
13
14  # -----
15  # Cargar datos
16  # -----
17
18  df = pd.read_csv("riesgos.csv", sep=";")
19
20  # -----
21  # Cálculo de riesgos
22  # -----
23
24  df["Riesgo_Inherente"] = (
25      df["Probabilidad_Inicial"] *
26      df["Impacto_Inicial"]
27  )
28
29  df["Riesgo_Residual"] = (
30      df["Probabilidad_Residual"] *
31      df["Impacto_Residual"]
32  )
33
34  # -----
35  # Reducción obtenida
36  # -----
37
38  df["Reduccion"] = (
39      df["Riesgo_Inherente"] -
40      df["Riesgo_Residual"]
41  )
42
43  df["Reduccion_%"] = (
44      df["Reduccion"] /
45      df["Riesgo_Inherente"] * 100

```

Figura 3: Fragmento representativo del simulador de análisis de riesgos desarrollado en Python.

La Figura 3 muestra un fragmento representativo del simulador desarrollado. Su inclusión tiene una finalidad documental: evidenciar que la parte práctica no se limita a una propuesta conceptual, sino que existe una implementación funcional que automatiza los cálculos descritos en la metodología. No se pretende analizar el código línea por línea, ya que el objetivo del TFG no es realizar una memoria de desarrollo software. El código completo se incorpora en los anexos para permitir su revisión y para reforzar la reproducibilidad del trabajo.

La automatización del cálculo aporta reproducibilidad. Si en una revisión posterior se modificase la probabilidad de un riesgo, el impacto de un escenario o la estimación residual tras aplicar un control, bastaría con actualizar el archivo de entrada y ejecutar de nuevo el simulador. El archivo de resultados y las figuras se regenerarían siguiendo las mismas reglas. Esta característica es

relevante porque la gestión de riesgos no debe entenderse como una fotografía cerrada, sino como un proceso revisable. En el contexto de una pequeña clínica, esta forma de trabajo permitiría actualizar periódicamente la matriz sin rediseñar toda la metodología.

También es importante destacar que el simulador no introduce criterios nuevos. No pondera activos mediante fórmulas distintas, no aplica aprendizaje automático, no consulta fuentes externas y no sustituye la valoración realizada en la memoria. Su comportamiento se limita a automatizar el cálculo definido previamente. Por ello, la implementación mantiene la coherencia con NIST SP 800-30: parte de escenarios de riesgo identificados, considera probabilidad e impacto, calcula el nivel resultante y facilita la revisión del riesgo residual después del tratamiento.

```
=====
SIMULADOR DE ANÁLISIS DE RIESGOS
Clínica SaludNova
=====

===== MATRIZ DE RIESGOS =====

ID      Riesgo      Riesgo_Inherente Nivel_Inherente  Riesgo_Residual Nivel_Residual Reduccion_%
0 R1      Ransomware en puestos internos      20      Crítico      8      Medio      60.00
1 R2      Robo de credenciales por phishing      20      Crítico      8      Medio      60.00
2 R3      Acceso indebido a historias clínicas      15      Alto      8      Medio      46.67
3 R4      Fuga por envío erróneo de informes      12      Medio      6      Bajo      50.00
4 R5      Indisponibilidad de aplicación SaaS      12      Medio      6      Bajo      50.00
5 R6      Copias de seguridad no recuperables      15      Alto      4      Bajo      73.33
6 R7      Movimiento lateral desde Wi-Fi invitados      12      Medio      3      Bajo      75.00
7 R8      Compromiso del acceso remoto del proveedor      15      Alto      8      Medio      46.67
8 R9      Pérdida o robo de portátil      8      Medio      3      Bajo      62.50
9 R10     Repositorio documental mal configurado      12      Medio      6      Bajo      50.00

=====
RESUMEN DEL ANÁLISIS
=====
Total de riesgos analizados: 10
Riesgo medio inicial: 14.10
Riesgo medio residual: 6.00
Reducción media: 57.42%
Mayor riesgo detectado: 20
Menor riesgo residual: 3

Distribución de riesgos:
Críticos : 2
Altos : 3
Medios : 5
Bajos : 0

Archivo riesgos_resultado.csv generado correctamente.
✓ Gráfico de barras generado.
✓ Matriz de riesgos generada.
✓ Gráfico de reducción generado.
```

Figura 4: Ejecución correcta del simulador y generación automática de resultados.

La Figura 4 evidencia la correcta ejecución del simulador desde la terminal. En ella se observa que el programa procesa los riesgos, muestra estadísticas generales, identifica los riesgos más críticos y confirma la generación de los archivos de salida. Esta captura refuerza la validación práctica porque demuestra que el proceso no se ha calculado manualmente para la memoria, sino que se ejecuta de forma automatizada a partir de los datos de entrada. De este modo, `riesgos_resultado.csv`, `barras.png`, `heatmap.png` y `reduccion.png` se obtienen como productos directos de la simulación.

7.4. Resultados obtenidos

El archivo `riesgos_resultado.csv` muestra que se han analizado diez riesgos. La suma del riesgo inherente es 141 puntos, mientras que la suma del riesgo residual es 60 puntos. Esto supone una reducción global aproximada del 57,45 %. El riesgo medio inicial es 14,10 y el riesgo medio residual es 6,00, lo que indica una disminución clara de la exposición agregada del caso SaludNova tras aplicar los controles propuestos.

Resultado	Valor	Interpretación
Riesgos analizados	10	Coinciden con los escenarios R1–R10 definidos en la matriz del caso de estudio.
Riesgo total inherente	141	Exposición agregada antes de aplicar el plan de ciberseguridad.
Riesgo total residual	60	Exposición agregada tras considerar los controles propuestos.
Reducción global	57,45 %	Disminución estimada del riesgo dentro del modelo Probabilidad $\times$ Impacto.
Riesgo medio inicial	14,10	Valor medio previo al tratamiento, situado en una zona de atención prioritaria.
Riesgo medio residual	6,00	Valor medio posterior al tratamiento, compatible con una situación más controlada.

Los riesgos con mayor puntuación inherente son R1, ransomware en puestos internos, y R2, robo de credenciales por phishing, ambos con una puntuación inicial de 20. Estos dos escenarios representan los riesgos críticos principales porque combinan alta probabilidad e impacto muy alto. Tras aplicar controles como autenticación multifactor, formación, copias verificadas, protección de puestos y procedimientos de respuesta, ambos se reducen a una puntuación residual de 8, con una reducción del 60 %. El tercer riesgo con mayor puntuación inicial es R3, acceso indebido a historias clínicas, con 15 puntos iniciales y 8 residuales, lo que equivale a una reducción del 46,67 %.

Tal y como puede observarse en la Figura 5, todos los riesgos presentan una reducción entre la situación inicial y la situación residual. El gráfico representa, para cada escenario R1–R10, la diferencia entre el valor de riesgo inherente y el valor de riesgo residual obtenido tras considerar los controles definidos en el plan de ciberseguridad. Esta comparación permite comprobar visualmente que la intervención propuesta no se limita a una mejora teórica, sino que produce una disminución cuantificable dentro del modelo aplicado.

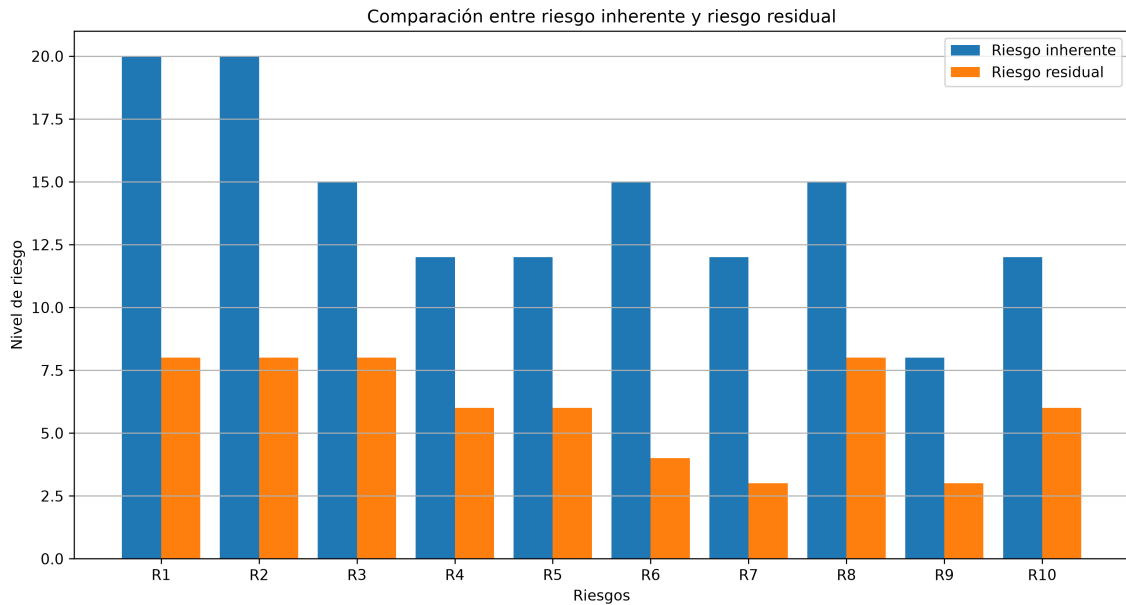


Figura 5: Comparación entre riesgo inherente y riesgo residual.

La Figura 5 permite apreciar especialmente la caída de R1 y R2, que parten de la puntuación máxima del conjunto analizado y descienden hasta un nivel residual notablemente inferior. También muestra que R3, R6 y R8, con puntuaciones inherentes de 15, siguen siendo riesgos relevantes aunque hayan disminuido. Esta interpretación es importante porque confirma que el plan de ciberseguridad no elimina el riesgo, sino que lo reduce hasta niveles más razonables para una organización pequeña o mediana.

La comparación entre riesgo inherente y residual también evidencia la función de los controles seleccionados. En R6, copias de seguridad no recuperables, el riesgo pasa de 15 a 4. Esta reducción se explica por la introducción de copias verificadas, pruebas de restauración y criterios de respaldo más robustos. En R7, movimiento lateral desde la red Wi-Fi de invitados, el riesgo pasa de 12 a 3, lo que refleja el efecto de la segmentación de red. Estos resultados son coherentes con el plan diseñado: los controles más directamente relacionados con una vulnerabilidad concreta producen reducciones más intensas.

El mapa de calor de la Figura 6 representa la distribución inicial de los riesgos según sus valores de probabilidad e impacto. Su utilidad consiste en mostrar dónde se concentra la exposición antes de aplicar los controles. La concentración más relevante se sitúa en zonas de impacto alto o muy alto, lo que resulta coherente con la naturaleza del caso de estudio: aunque no todos los escenarios tienen la misma probabilidad, la afectación potencial de datos sanitarios eleva el impacto de una parte significativa de los riesgos.

Los resultados representados en la Figura 6 muestran que SaludNova no se enfrenta únicamente a riesgos de baja severidad. R1 y R2 aparecen en la zona de mayor criticidad, mientras que R3, R6 y R8 se sitúan en posiciones de impacto muy alto con probabilidad media. Esta distribución confirma la necesidad de priorizar controles relacionados con credenciales, ransomware, copias

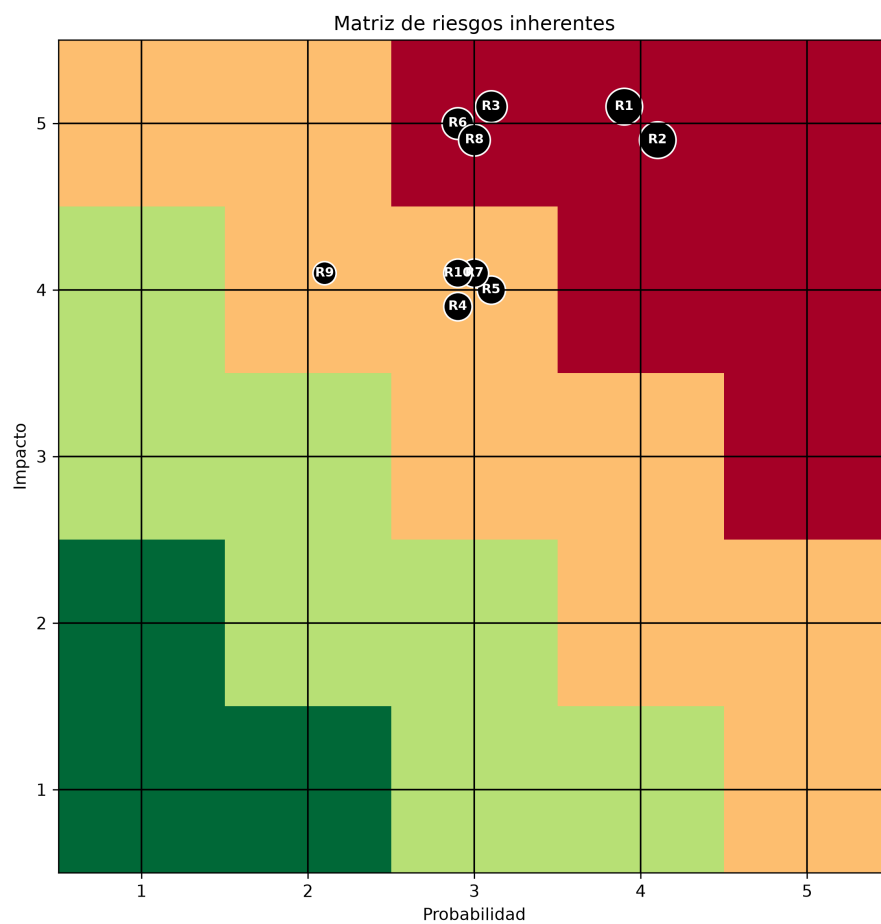


Figura 6: Mapa de calor de los riesgos inherentes.

de seguridad, accesos a historias clínicas y proveedor TIC. El mapa de calor permite, por tanto, conectar visualmente el análisis de riesgos con la hoja de ruta de implantación del plan de ciberseguridad.

La concentración de riesgos en zonas de impacto elevado se justifica por el tipo de activos tratados. Historias clínicas, credenciales, copias de seguridad y accesos de proveedor tienen una criticidad superior a la de otros activos porque una pérdida de confidencialidad, integridad o disponibilidad podría afectar a datos sanitarios, continuidad asistencial y cumplimiento normativo. Por ello, el mapa de calor no solo resume puntuaciones, sino que ayuda a priorizar el tratamiento: los riesgos situados en las zonas de mayor severidad deben abordarse antes que aquellos con impacto más limitado o probabilidad inferior.

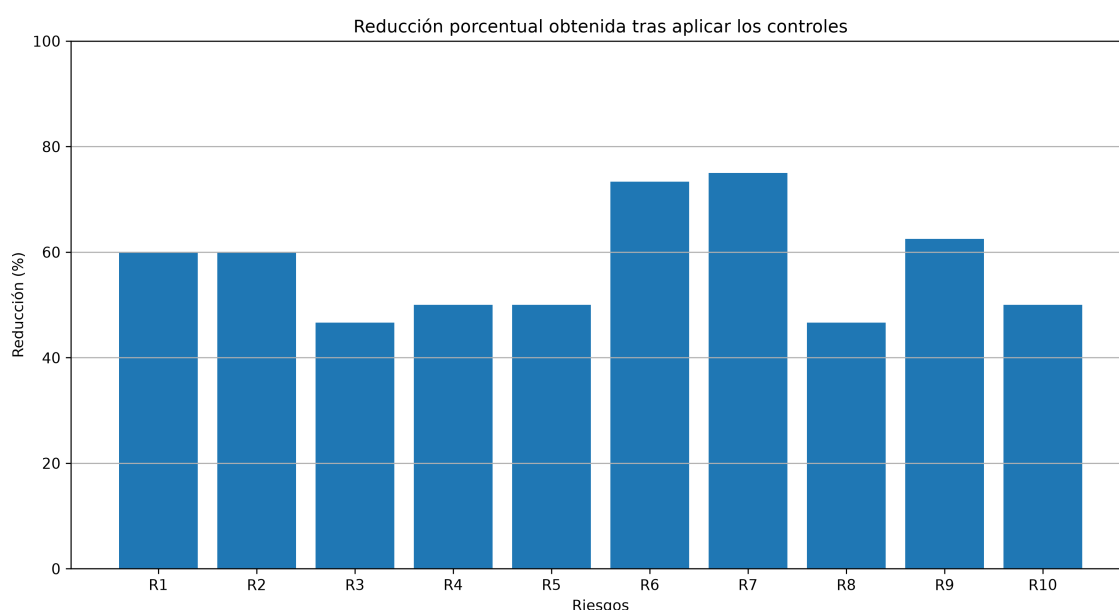


Figura 7: Reducción porcentual del riesgo tras aplicar los controles.

La Figura 7 muestra la reducción porcentual obtenida para cada riesgo. Esta figura complementa al gráfico de barras porque no solo indica la puntuación final, sino la intensidad relativa de la mejora. Los mayores porcentajes de reducción se observan en R7, con un 75 %, y R6, con un 73,33 %. Estos resultados indican que los controles propuestos para segmentación de red y recuperabilidad de copias tienen un efecto especialmente claro sobre los escenarios a los que se dirigen.

El gráfico de reducción porcentual también permite identificar riesgos que, aunque mejoran, siguen requiriendo seguimiento. R3 y R8 presentan reducciones del 46,67 %, inferiores a las de otros escenarios, y mantienen una puntuación residual de 8. Esto no implica que los controles sean ineficaces, sino que se trata de riesgos estructuralmente sensibles: el acceso a historias clínicas y el acceso remoto del proveedor continúan siendo actividades necesarias para la operación de la clínica. En estos casos, la estrategia adecuada no es esperar riesgo cero, sino mantener controles, registros, revisión de permisos y supervisión periódica.

La interpretación de la Figura 7 confirma una idea central de la gestión de riesgos: los controles reducen la exposición, pero no eliminan por completo la posibilidad de incidente. En un entorno eHealth, algunos procesos deben seguir existiendo para que la clínica funcione, como el acceso a información clínica, el uso del correo electrónico o la intervención del proveedor TIC. Por ello, el riesgo residual no debe considerarse un fallo del plan, sino una consecuencia normal de operar sistemas reales con datos sensibles.

7.5. Discusión de resultados

El análisis conjunto de las figuras permite valorar la coherencia global de la propuesta. La Figura 5 muestra que todos los riesgos disminuyen tras aplicar controles; la Figura 6 permite entender por qué algunos escenarios debían tratarse con prioridad; y la Figura 7 muestra que la reducción no es homogénea, sino que depende del tipo de vulnerabilidad tratada y del margen realista de mitigación.

Esta lectura conjunta valida la coherencia de la metodología aplicada. Los riesgos que aparecían como prioritarios en la matriz inicial son precisamente los que reciben controles más relevantes en el plan de ciberseguridad. A su vez, los resultados residuales reflejan que los controles seleccionados reducen significativamente la exposición global, pero no eliminan completamente el riesgo. Este comportamiento es metodológicamente razonable: si la simulación hubiese reducido todos los riesgos a cero, el resultado sería poco realista; si no hubiese reducido ninguno, el plan carecería de eficacia. La situación obtenida, con una reducción global del 57,45 % y con varios riesgos aún sujetos a seguimiento, resulta coherente con una organización sanitaria pequeña o mediana.

La discusión también muestra que la simulación aporta una evidencia práctica de trazabilidad. Cada resultado puede explicarse desde la relación entre activo, amenaza, vulnerabilidad y control. Por ejemplo, la reducción de R6 se vincula con controles de respaldo y restauración; la de R7 con segmentación de red; la de R1 y R2 con formación, MFA y medidas preventivas frente a ransomware y phishing. Esta correspondencia evita que el plan de ciberseguridad se perciba como una lista genérica de medidas y refuerza la idea de que cada control responde a un riesgo previamente identificado.

En términos agregados, los resultados muestran una reducción global suficiente para justificar la eficacia del plan propuesto dentro del alcance del TFG. La puntuación total pasa de 141 a 60, y ningún riesgo queda con puntuación residual crítica. Sin embargo, varios riesgos permanecen en niveles que exigen monitorización, especialmente R1, R2, R3 y R8, todos con puntuación residual de 8. Esta situación es realista: en un entorno sanitario con datos sensibles, ciertos riesgos no pueden eliminarse por completo mientras la organización siga utilizando sistemas digitales, proveedores externos y comunicaciones electrónicas.

7.6. Utilidad de la validación

La utilidad principal del simulador es aportar una capa de comprobación entre la matriz de riesgos y las conclusiones. Sin esta validación, el trabajo podría presentar una matriz inicial, un plan de controles y una estimación residual, pero la relación entre esos elementos quedaría menos visible. Con el simulador, el lector puede comprobar que las mismas reglas se aplican a todos los riesgos y que las reducciones se derivan de valores explícitos.

Para una pequeña clínica, esta aproximación tendría además utilidad práctica. No sustituiría una auditoría ni una herramienta profesional, pero permitiría mantener un registro básico de riesgos, actualizar puntuaciones tras implantar controles y generar evidencias comprensibles para dirección. En organizaciones con recursos limitados, este tipo de instrumento puede facilitar la conversación entre perfiles técnicos y no técnicos, ya que transforma una discusión abstracta sobre ciberseguridad en resultados observables: qué riesgos son prioritarios, cuánto se reducen y cuáles deben seguir revisándose.

Desde el punto de vista del TFG, la validación demuestra que la metodología no se queda en una formulación teórica. El análisis se convierte en un proceso operativo: se definen datos de entrada, se aplican reglas, se generan salidas y se interpretan resultados. Esta continuidad narrativa refuerza la estructura completa del documento: problema, marco teórico, caso de estudio, análisis, controles, simulación y conclusiones.

7.7. Limitaciones y cierre de la validación

La validación presenta limitaciones que deben interpretarse correctamente. En primer lugar, los datos utilizados proceden del caso ficticio SaludNova, por lo que las puntuaciones no representan mediciones reales de incidentes. En segundo lugar, el simulador no verifica técnicamente que los controles estén implantados ni que funcionen en producción. Por ejemplo, una reducción del riesgo asociado al ransomware presupone que las copias se verifican, que la formación se realiza y que los procedimientos se aplican; el simulador no comprueba esas condiciones por sí mismo.

En tercer lugar, el modelo conserva la simplicidad de la matriz Probabilidad $\times$ Impacto. Esta simplicidad es adecuada para el alcance del TFG, pero no captura todos los matices posibles de una evaluación profesional, como estimaciones económicas detalladas, dependencia entre riesgos, frecuencia histórica de incidentes o madurez real de controles. En cuarto lugar, las figuras generadas dependen de la calidad de los datos de entrada. Si las puntuaciones iniciales o residuales no estuvieran justificadas, la automatización no corregiría el problema metodológico.

Estas limitaciones no invalidan la práctica, sino que delimitan su finalidad. El simulador desarrollado no pretende sustituir herramientas profesionales de análisis de riesgos, plataformas de gobierno de seguridad o auditorías especializadas. Su aportación es actuar como una validación práctica de la metodología aplicada durante el TFG, aportando trazabilidad, reproducibilidad y evidencia de los resultados obtenidos. Esta interpretación mantiene el alcance del trabajo ba-

jo control y evita presentar la implementación como una solución profesional. La contribución práctica es suficiente para un TFG centrado en gestión de riesgos porque demuestra que el análisis puede ejecutarse de forma ordenada y que sus resultados son coherentes con el plan de ciberseguridad propuesto.

8. Conclusiones y líneas futuras

El desarrollo del trabajo permite concluir que una organización sanitaria de tamaño pequeño o medio puede presentar un nivel de exposición significativo aunque no disponga de una infraestructura especialmente compleja. La clínica SaludNova, aun siendo un caso ficticio, reproduce una situación habitual en el ámbito eHealth: tratamiento de datos clínicos sensibles, dependencia de servicios digitales, soporte TIC externalizado, uso intensivo del correo electrónico y necesidad de continuidad asistencial. Esta combinación convierte a la organización en un entorno suficientemente realista para aplicar una metodología formal de análisis de riesgos sin recurrir a una auditoría real ni al tratamiento de datos auténticos.

La principal aportación del TFG es la construcción de una cadena de trazabilidad entre activos, amenazas, vulnerabilidades, riesgos, controles, riesgo residual y validación práctica. Esta trazabilidad permite que el plan de ciberseguridad no sea una enumeración genérica de buenas prácticas, sino una respuesta razonada a riesgos concretos. El trabajo muestra que controles como MFA, mínimo privilegio, copias verificadas, segmentación, formación, gestión de proveedores y respuesta a incidentes tienen sentido porque se relacionan directamente con riesgos previamente priorizados. Esta conexión constituye el núcleo académico del proyecto y refuerza su defendibilidad ante un tribunal.

La metodología basada en NIST SP 800-30, adaptada mediante una matriz semicuantitativa Probabilidad $\times$ Impacto, ha resultado adecuada para el alcance definido. Su principal ventaja es que permite ordenar el análisis de forma clara sin exigir datos estadísticos o económicos que no están disponibles en un caso ficticio. La comparación con alternativas como MAGERIT o ISO/IEC 27005 permite justificar que la elección metodológica no responde a desconocimiento de otros marcos, sino a una decisión de proporcionalidad. El trabajo no pretende aplicar de forma exhaustiva una metodología corporativa, sino utilizar un modelo suficientemente riguroso para valorar riesgos y orientar controles.

El análisis identifica como escenarios prioritarios el ransomware, el robo de credenciales por phishing, el acceso indebido a historias clínicas, la falta de recuperabilidad de copias de seguridad y el compromiso del acceso remoto del proveedor. Estos riesgos son coherentes con el contexto de SaludNova porque afectan a activos críticos y combinan probabilidad razonable con impacto elevado. Además, muestran que las amenazas más relevantes para una clínica pequeña no tienen por qué ser técnicamente sofisticadas. En muchos casos, el riesgo surge de la combinación de procesos cotidianos, usuarios con distintos perfiles, controles insuficientemente formalizados y dependencia de terceros.

El plan de ciberseguridad diseñado demuestra que una reducción significativa del riesgo puede alcanzarse mediante medidas proporcionadas. No se requiere implantar un SGSI completo ni desplegar soluciones avanzadas para obtener mejoras relevantes. La activación de MFA, la revisión de permisos, la verificación de copias, la segmentación básica, la formación periódica, la formalización de relaciones con proveedores y la existencia de un procedimiento de incidentes son medidas asumibles para una clínica de las características descritas. Su valor reside en que reducen tanto la probabilidad de determinados incidentes como el impacto en caso de materializarse.

La implementación del simulador refuerza esta conclusión al automatizar el cálculo de riesgo inherente, riesgo residual y reducción porcentual. El resultado agregado muestra una disminución del riesgo total de 141 a 60 puntos, equivalente a una reducción aproximada del 57,45 %. Esta cifra no debe interpretarse como una medición real de seguridad, sino como una evidencia metodológica de que los controles seleccionados producen una reducción coherente dentro del modelo definido. La generación automática de `riesgos_resultado.csv` y de las figuras comparativas aporta transparencia, facilita la revisión del análisis y demuestra que la matriz puede reproducirse de manera sistemática.

Una conclusión importante es que el riesgo no desaparece tras aplicar controles. La seguridad debe entenderse como un proceso de reducción, aceptación y revisión, no como un estado definitivo. El riesgo residual permanece y debe ser asumido de forma consciente por la dirección de la clínica. Esta responsabilidad no puede delegarse por completo en el proveedor TIC, ya que la organización sigue siendo responsable de los datos tratados y de las decisiones sobre nivel de riesgo aceptable. Por tanto, la revisión periódica de la matriz, la documentación de decisiones y el seguimiento de indicadores son elementos necesarios para mantener la utilidad del plan.

La validación práctica mediante simulador sencillo aporta una evidencia complementaria adecuada al enfoque del TFG. Su finalidad no es demostrar seguridad real ni sustituir una auditoría, sino comprobar que el modelo de valoración es reproducible y que los resultados pueden visualizarse de forma clara. La automatización del cálculo, la identificación de los riesgos más críticos y la generación de gráficos permiten enlazar la parte analítica con la interpretación final de resultados. Esta práctica mantiene el equilibrio entre componente aplicado y carga de trabajo, evitando convertir la memoria en un proyecto de desarrollo software.

La aplicabilidad práctica del trabajo se extiende a pequeñas clínicas, centros sanitarios privados o entidades que traten datos personales sensibles con recursos limitados. El enfoque puede adaptarse a otros contextos siempre que se redefinan activos, amenazas, vulnerabilidades y criterios de impacto. La mayor utilidad reside en ofrecer una forma ordenada de priorizar riesgos y seleccionar controles proporcionados, especialmente para organizaciones que necesitan mejorar su postura de ciberseguridad sin asumir proyectos de gran complejidad. En este sentido, el simulador también puede entenderse como una herramienta de apoyo a la revisión interna, siempre que se utilice con prudencia y con datos suficientemente justificados.

El trabajo presenta, no obstante, limitaciones claras. La clínica es ficticia y, por tanto, las puntuaciones de probabilidad e impacto se basan en supuestos razonados y no en datos históricos reales.

Tampoco se validan técnicamente los controles en un entorno productivo ni se realiza pentesting, análisis forense, auditoría de cumplimiento o implantación formal de ISO 27001. El simulador no comprueba la eficacia real de los controles; únicamente automatiza el cálculo definido por la metodología. Estas limitaciones no invalidan el resultado, pero delimitan su interpretación: el TFG ofrece un modelo académico de análisis, planificación y validación metodológica, no una certificación de seguridad ni una evaluación profesional completa.

Como líneas futuras, el trabajo podría ampliarse en varias direcciones sin alterar la base metodológica desarrollada. Una primera línea sería contrastar el caso ficticio mediante entrevistas con profesionales sanitarios o responsables TIC, con el fin de ajustar supuestos y puntuaciones. Una segunda posibilidad sería incorporar métricas reales de revisión, como tiempos de recuperación, resultados de simulaciones de phishing, número de incidencias registradas o periodicidad de pruebas de restauración. También podría ampliarse el simulador para permitir escenarios alternativos, ponderaciones por tipo de activo o asociación más detallada con controles ISO, siempre manteniendo su función como apoyo metodológico y no como herramienta profesional. Finalmente, podría aplicarse el mismo enfoque a otras pequeñas organizaciones que traten datos sensibles para comprobar la transferibilidad del modelo.

En conjunto, el TFG cumple su objetivo al diseñar un análisis de riesgos y un plan de ciberseguridad aplicado a un entorno eHealth con datos sensibles. El documento plantea un problema, lo fundamenta teóricamente, define un caso de estudio, aplica una metodología formal, identifica riesgos, propone controles, estima el riesgo residual y valida la coherencia del análisis mediante un simulador académico. Su contribución no se basa en desarrollar una herramienta compleja, sino en integrar metodología, normativa, caso de estudio, controles, automatización ligera y conclusiones en una propuesta coherente, proporcional y defendible. Esta aproximación resulta adecuada para un Trabajo de Fin de Grado de Ingeniería Informática porque combina fundamentos técnicos, razonamiento metodológico, comprensión del contexto organizativo y una aplicación práctica ajustada al alcance disponible.

A. Anexos

A.1. Anexo A. Fragmentos representativos del simulador

Este anexo recoge fragmentos representativos del simulador desarrollado en Python. No se incluye el código completo para evitar una extensión innecesaria de la memoria; se seleccionan únicamente las partes que evidencian la lectura del archivo de entrada, el cálculo del riesgo, la generación de estadísticas y la creación de las figuras utilizadas en la validación práctica.

Lectura del CSV

```
import pandas as pd
import matplotlib.pyplot as plt
```

```
# Cargar datos de entrada
df = pd.read_csv("riesgos.csv", sep=";")
```

Este fragmento muestra la carga del archivo `riesgos.csv`, que actúa como entrada estructurada del simulador. Cada fila del archivo representa uno de los riesgos definidos en el análisis del caso SaludNova.

Cálculo de riesgo inherente, residual y reducción

```
df["Riesgo_Inherente"] = (
    df["Probabilidad_Inicial"] *
    df["Impacto_Inicial"]
)

df["Riesgo_Residual"] = (
    df["Probabilidad_Residual"] *
    df["Impacto_Residual"]
)

df["Reduccion"] = (
    df["Riesgo_Inherente"] -
    df["Riesgo_Residual"]
)

df["Reduccion_%"] = (
    df["Reduccion"] /
    df["Riesgo_Inherente"] * 100
).round(2)
```

Este bloque automatiza la regla metodológica utilizada en la memoria: el riesgo se calcula como producto de probabilidad e impacto, y la reducción se obtiene comparando la situación inherente con la residual.

Clasificación y estadísticas

```
def clasificar(valor):
    if valor >= 20:
        return "Critico"
    elif valor >= 15:
        return "Alto"
    elif valor >= 8:
        return "Medio"
    else:
        return "Bajo"
```

```

df["Nivel_Inherente"] = df["Riesgo_Inherente"].apply(clasificar)
df["Nivel_Residual"] = df["Riesgo_Residual"].apply(clasificar)

print(f"Total de riesgos analizados: {len(df)}")
print(f"Riesgo medio inicial: {df['Riesgo_Inherente'].mean():.2f}")
print(f"Riesgo medio residual: {df['Riesgo_Residual'].mean():.2f}")
print(f"Reduccion media: {df['Reduccion_%'].mean():.2f}%")

```

La clasificación permite transformar las puntuaciones numéricas en niveles interpretables y facilita la comparación entre el análisis inicial y la situación residual.

Generación del gráfico de barras

```

plt.figure(figsize=(11,6))
x = range(len(df))

plt.bar([i-0.2 for i in x], df["Riesgo_Inherente"],
        width=0.4, label="Riesgo inherente")
plt.bar([i+0.2 for i in x], df["Riesgo_Residual"],
        width=0.4, label="Riesgo residual")

plt.xticks(x, df["ID"])
plt.xlabel("Riesgos")
plt.ylabel("Nivel de riesgo")
plt.title("Comparacion entre riesgo inherente y riesgo residual")
plt.legend()
plt.tight_layout()
plt.savefig("barras.png", dpi=300)
plt.close()

```

Este fragmento genera la figura que compara riesgo inherente y residual para cada escenario R1–R10.

Generación del mapa de calor

```

import numpy as np

plt.figure(figsize=(8,8))
matriz = np.array([
    [1,1,2,2,3],
    [1,2,2,3,3],
    [2,2,3,3,4],
    [2,3,3,4,4],
    [3,3,4,4,4]
])

```

```

])

plt.imshow(matriz, origin="lower", cmap="RdYlGn_r",
           extent=[0.5,5.5,0.5,5.5])

for _, fila in df.iterrows():
    plt.scatter(fila["Probabilidad_Inicial"],
                fila["Impacto_Inicial"],
                s=fila["Riesgo_Inherente"]*25,
                color="black", edgecolors="white")
    plt.text(fila["Probabilidad_Inicial"],
             fila["Impacto_Inicial"],
             fila["ID"], color="white",
             ha="center", va="center", fontweight="bold")

plt.xlabel("Probabilidad")
plt.ylabel("Impacto")
plt.title("Matriz de riesgos inherentes")
plt.tight_layout()
plt.savefig("heatmap.png", dpi=300)
plt.close()

```

El mapa de calor permite ubicar cada riesgo según probabilidad e impacto, reforzando la priorización visual de los escenarios más relevantes.

Generación del gráfico de reducción

```

plt.figure(figsize=(11,6))
plt.bar(df["ID"], df["Reduccion_%"])
plt.xlabel("Riesgos")
plt.ylabel("Reduccion (%)")
plt.title("Reduccion porcentual obtenida tras aplicar los controles")
plt.ylim(0,100)
plt.grid(axis="y")
plt.tight_layout()
plt.savefig("reduccion.png", dpi=300)
plt.close()

```

Este gráfico muestra la reducción porcentual alcanzada por cada riesgo y complementa la comparación entre valores inherentes y residuales.

A.2. Anexo B. Contenido del archivo riesgos.csv

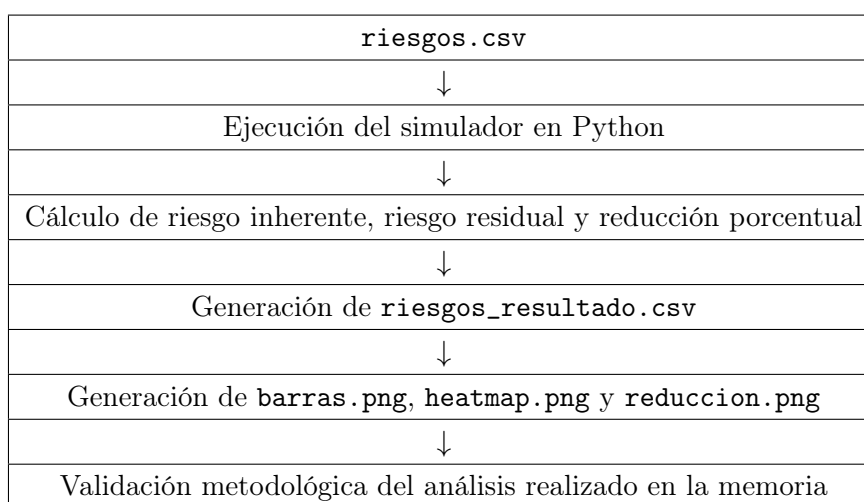
El archivo `riesgos.csv` constituye la entrada del simulador. Su contenido reproduce los diez riesgos analizados en la memoria y recoge los valores de probabilidad e impacto iniciales y resi-

duales.

ID	Riesgo	P. inicial	I. inicial	R. inicial	P. residual	I. residual	R. residual
R1	Ransomware en puestos internos	4	5	20	2	4	8
R2	Robo de credenciales por phishing	4	5	20	2	4	8
R3	Acceso indebido a historias clínicas	3	5	15	2	4	8
R4	Fuga por envío erróneo de informes	3	4	12	2	3	6
R5	Indisponibilidad de aplicación SaaS	3	4	12	2	3	6
R6	Copias de seguridad no recuperables	3	5	15	1	4	4
R7	Movimiento lateral desde Wi-Fi invitados	3	4	12	1	3	3
R8	Compromiso del acceso remoto del proveedor	3	5	15	2	4	8
R9	Pérdida o robo de portátil	2	4	8	1	3	3
R10	Repositorio documental mal configurado	3	4	12	2	3	6

A.3. Anexo C. Flujo de ejecución del simulador

El flujo de ejecución del simulador puede resumirse como una cadena sencilla y reproducible:



Este flujo muestra que la práctica no introduce una metodología paralela, sino que automatiza la ya utilizada en el TFG. El CSV proporciona los datos de entrada, Python ejecuta los cálculos, los resultados se almacenan y visualizan, y las salidas permiten comprobar la coherencia entre análisis de riesgos, controles propuestos y riesgo residual.

B. Referencias

Referencias

- [1] European Parliament and Council of the European Union. Regulation (eu) 2016/679 of the european parliament and of the council of 27 april 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (GDPR). EUR-Lex, Official Journal of the European Union, L 119/1, 2016. Consolidated legal text.
- [2] European Union Agency for Cybersecurity (ENISA). Cybersecurity in healthcare — sectoral guidance and threat landscape resources. Official guidance and sector resources, 2024.
- [3] International Organization for Standardization. ISO/IEC 27001:2022 information security, cybersecurity and privacy protection — information security management systems — requirements. International Standard, 2022. Edition 3.
- [4] International Organization for Standardization. ISO/IEC 27002:2022 information security, cybersecurity and privacy protection — information security controls. International Standard, 2022. Edition 3.
- [5] International Organization for Standardization. ISO/IEC 27005:2022 information security, cybersecurity and privacy protection — guidance on managing information security risks. International Standard, 2022. Edition 4.
- [6] International Organization for Standardization. ISO 27799:2025 health informatics — information security controls in health based on ISO/IEC 27002. International Standard, 2025. Edition 3.
- [7] Jefatura del Estado. Ley orgánica 3/2018, de 5 de diciembre, de protección de datos personales y garantía de los derechos digitales. Boletín Oficial del Estado, BOE-A-2018-16673, 2018. Última actualización consultada en 2026.
- [8] Ministerio de Hacienda y Administraciones Públicas. Magerit – versión 3.0. metodología de análisis y gestión de riesgos de los sistemas de información. Administración electrónica, Gobierno de España, 2012.
- [9] National Institute of Standards and Technology. The nist cybersecurity framework 2.0. Technical report, National Institute of Standards and Technology, 2024.
- [10] Ronald Ross. Guide for conducting risk assessments. Technical Report NIST SP 800-30 Rev. 1, National Institute of Standards and Technology, 2012.